

GIUGNO
2026

ICT
Security
MAGAZINE

Contrattualizzazione e allocazione delle responsabilità nei modelli di IA: AI Act, NIS2 e profili critici

A cura di **Chiara De Filippo**

www.ictsecuritymagazine.com

INDICE

3 ABOUT THE AUTHOR

3 Chiara De Filippo

4 INTRODUZIONE

8 CAPITOLO 1 - INQUADRAMENTO NORMATIVO: IL REGOLAMENTO (UE) 2024/1689 [AI ACT] E LA DIRETTIVA (UE) 2022/2555 [NIS2]

- 9 1.1 - L'AI Act: struttura, finalità e ambito di applicazione. L'approccio risk-based
- 21 1.2 - La Direttiva NIS2: finalità e novità introdotte rispetto alla NIS1
- 29 1.3 - Interazioni tra AI Act e NIS2 nella disciplina dei modelli di IA
- 32 1.4 - Profili di responsabilità emergenti dal quadro normativo europeo
- 35 1.5 - La Direttiva (UE) 2024/2853 sulla responsabilità per danno da prodotti difettosi: il nuovo tassello del quadro europeo

38 CAPITOLO 2 - I SERVIZI DI INTELLIGENZA ARTIFICIALE NEI MODELLI CONTRATTUALI ESISTENTI

- 39 2.1 - I modelli di IA come servizi digitali
- 42 2.2 - Analisi dei principali servizi di IA nel contesto attuale: ChatGPT (OpenAI)
- 52 2.3 - Profili critici di compatibilità con AI Act e NIS2

58 CAPITOLO 3 - LE LINEE GUIDA AGID E PROBLEMATICHE DI RESPONSABILITÀ

- 57 3.1 - Il ruolo di AgID nella governance dell'IA
- 59 3.2 - Le Linee Guida AgID sull'uso dell'IA nella Pubblica Amministrazione
- 63 3.3 - La responsabilità della Pubblica Amministrazione nell'adozione di modelli di IA
- 70 3.4 - IA, sicurezza e responsabilità per incidenti e malfunzionamenti. Applicazioni pratiche
- 75 3.5 - Coordinamento tra Linee Guida AgID, AI Act e NIS2: dove si arresta la norma e interviene il contratto

78 CAPITOLO 4 - PROFILI EVOLUTIVI: DAL LIMITE DELLA NORMA ALLA CONTRATTUALIZZAZIONE COME STRUMENTO RISOLUTIVO

- 79 4.1 - La non prevedibilità degli output dell'IA come problema giuridico di partenza
- 83 4.2 - La contrattualizzazione della responsabilità come risposta funzionale
- 95 4.3 - Prospettive evolutive e considerazioni conclusive

98 BIBLIOGRAFIA

102 SITOGRAFIA

ABOUT THE AUTHOR

Tirocinante presso la Suprema Corte di Cassazione e praticante avvocato, con una formazione specialistica in informatica giuridica, protezione dei dati personali, cybersecurity e diritto delle nuove tecnologie. Ha maturato competenze nell'analisi dei profili giuridici legati all'intelligenza artificia-

le, alla trasformazione digitale e alla regolazione delle tecnologie emergenti, con particolare attenzione alla responsabilità, alla contrattualistica dei sistemi basati su IA, alla data protection, alla governance digitale, alla gestione del rischio legale e alla compliance normativa.

CHIARA DE FILIPPO

ESPERTA IN DIRITTO DELL'INNOVAZIONE
TECNOLOGICA, INTELLIGENZA ARTIFI-
CIALE E COMPLIANCE DIGITALE





INTRODUZIONE



Negli ultimi anni l'Intelligenza Artificiale ha assunto un ruolo sempre più centrale nei processi economici, sociali e istituzionali, incidendo profondamente sulle modalità di produzione, gestione e utilizzo delle informazioni.

I sistemi di IA, in particolare quelli basati su tecniche di apprendimento automatico e su architetture di *deep learning*, sono oggi impiegati in una pluralità di ambiti – dai servizi digitali alla ricerca scientifica, dalla sanità alla pubblica amministrazione – contribuendo a trasformare in modo significativo l'organizzazione delle attività economiche e delle relazioni giuridiche tra gli operatori.

La crescente diffusione di tali tecnologie ha posto il Legislatore di fronte alla necessità di elaborare strumenti normativi idonei a governare i rischi connessi al loro utilizzo, garantendo al tempo stesso lo sviluppo dell'innovazione tecnologica.

In questo contesto si inserisce il progressivo consolidamento di una disciplina europea dell'intelligenza artificiale, culminato nell'adozione del Regolamento (UE) 2024/1689 (AI Act), primo intervento organico volto a regolamentare i sistemi di IA attraverso un approccio basato sul rischio.

A tale disciplina si affianca la Direttiva (UE) 2022/2555 (NIS2), che rafforza il quadro europeo di sicurezza informatica e introduce obblighi di gestione del rischio e di resilienza digitale per un ampio numero

di operatori economici e istituzioni pubbliche.

Sebbene tali strumenti normativi perseguano finalità in parte differenti, essi concorrono a delineare un sistema di *governance* delle tecnologie digitali fondato su principi di prevenzione, sicurezza e responsabilizzazione degli operatori.

Tuttavia, la complessità tecnica dei sistemi di Intelligenza Artificiale e la pluralità di soggetti coinvolti nella loro progettazione, sviluppo e utilizzo rendono difficile per la sola regolazione pubblica disciplinare in modo esaustivo tutte le possibili configurazioni operative di tali tecnologie. In particolare, i modelli di IA si caratterizzano spesso per un funzionamento dinamico ed evolutivo, che può generare risultati non pienamente prevedibili e che si inserisce all'interno di ecosistemi tecnologici articolati, nei quali interagiscono diversi livelli della *supply chain* digitale.

In questo scenario emergono con particolare evidenza alcune questioni giuridiche relative alla distribuzione delle responsabilità tra i soggetti coinvolti nello sviluppo e nell'utilizzo dei sistemi di Intelligenza Artificiale. Il quadro normativo europeo appare

infatti prevalentemente orientato alla prevenzione e alla gestione del rischio, attraverso l'introduzione di obblighi di sicurezza, trasparenza e controllo, mentre rimangono in parte aperti i problemi relativi alla concreta allocazione delle responsabilità nei rapporti tra gli operatori.

Proprio in tale contesto assume particolare rilievo il ruolo degli strumenti contrattuali.

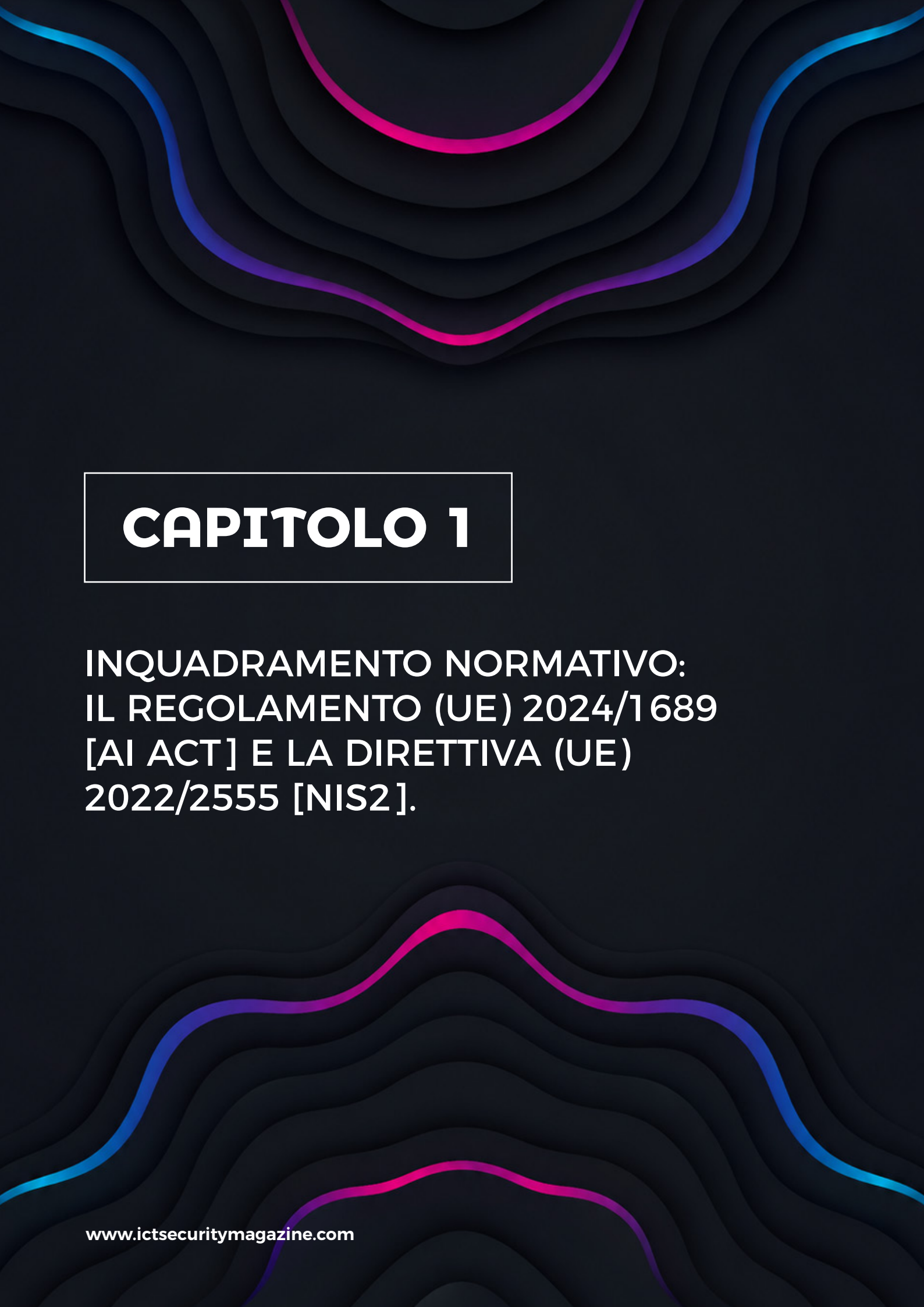
I contratti di fornitura dei servizi di Intelligenza Artificiale e le condizioni d'uso delle piattaforme digitali rappresentano infatti uno dei principali strumenti attraverso i quali i soggetti coinvolti nella filiera tecnologica definiscono la distribuzione degli obblighi e delle responsabilità connesse all'utilizzo di tali sistemi.

La contrattualizzazione consente, in questo senso, di adattare la gestione del rischio alle specificità dei singoli contesti operativi, integrando e rendendo concretamente applicabili i principi generali stabiliti dalla normativa europea.

Alla luce di tali premesse, la presente ricerca si propone di analizzare il rapporto tra regolazione pubblica e autonomia negoziale nella disciplina

dei sistemi di Intelligenza Artificiale, con particolare attenzione ai profili di responsabilità che emergono dall'interazione tra AI Act, direttiva NIS2 e prassi contrattuali adottate dai fornitori di servizi di IA.

L'obiettivo è quello di verificare in che misura il contratto possa svolgere una funzione integrativa rispetto al quadro normativo europeo, contribuendo alla gestione dei rischi connessi all'utilizzo di tecnologie caratterizzate da elevata complessità e da un grado fisiologico di imprevedibilità.



CAPITOLO 1

**INQUADRAMENTO NORMATIVO:
IL REGOLAMENTO (UE) 2024/1689
[AI ACT] E LA DIRETTIVA (UE)
2022/2555 [NIS2].**



L'AI Act: struttura, finalità e ambito di applicazione. L'approccio *risk-based*.

Lo sviluppo e l'impiego dei modelli di Intelligenza Artificiale hanno sollevato negli ultimi anni questioni giuridiche nuove, inedite e particolarmente spinose, riconducibili inevitabilmente alla natura intrinsecamente probabilistica e non deterministica di tali strumenti digitali.

La sfida è stata da subito raccolta dalle Istituzioni Europee, che hanno manifestato particolare attenzione nell'evitare un'eccessiva frammentazione tra

gli Stati membri, individuando la necessità di stabilire un quadro normativo di riferimento capace, da un lato, di garantire la protezione dei diritti e, dall'altro, di accompagnare il progresso tecnologico, regolamentandolo senza comprometterne lo sviluppo.¹

In questo contesto si inserisce il Regolamento (UE) 2024/1689 (AI Act),² primo tentativo a livello sovranazionale di regolazione dell'IA, in vigore dal 1° agosto 2024.³

¹ D'Antino V., *L'approccio basato sul rischio nell'AI Act: un nuovo paradigma di regolazione dell'intelligenza artificiale*, in *federalismi.it*, 2025, 16.

² Regolamento (UE) 2024/1689 (AI Act): <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>.

³ Il testo legislativo dell'AI Act rappresenta il culmine di un processo graduale e di un lungo dibattito, in cui si inseriscono dapprima la Comunicazione COM(2018) 237, "Artificial Intelligence for Europe", con il quale si inizia a delineare un quadro etico e giuridico per l'utilizzo dell'IA che garantisca il rispetto dei diritti fondamentali; in seguito, nel 2019, la pubblicazione delle "Ethics Guidelines for Trustworthy AI" da parte dell'AI HLEG (High-Level Expert Group on AI), le quali definiscono i requisiti chiave per garantire un sufficiente grado di affidabilità dei sistemi IA, successivamente trasposti nel testo dell'AI Act. Nel febbraio 2020 viene poi presentato dalla Commissione il Libro Bianco sull'IA ("White Paper on Artificial Intelligence – A European Approach to Excellence and Trust" COM(2020) 65 final) che vede la partecipazione e la consultazione di numerosi soggetti sia pubblici che privati e getta le basi per il futuro regolamento.

Tale atto normativo adotta un approccio fondato sulla valutazione, categorizzazione e gestione del rischio ⁴ e riflette la particolare scelta del Legislatore europeo di non neutralizzare l'incertezza dei sistemi di IA, ma di prevenirne e mitigarne gli effetti potenzialmente dannosi mediante l'imposizione di obblighi organizzativi, tecnici e procedurali ai soggetti coinvolti nello sviluppo e nell'utilizzo dei diversi sistemi.

L'imprevedibilità, infatti benché non espressamente definita dalla normativa, viene assunta come dato strutturale dei sistemi di IA e ne costituisce presupposto implicito: il Legislatore prende atto del fatto che in presenza di determinati sistemi, come quelli basati su tecniche di *machine learning* o come i modelli c.d. *general-purpose*, gli esiti prodotti non risultano determinabili né controllabili *ex ante*.

Da tale assunto prendono vita le disposizioni del Regolamento, la

cui struttura riflette un approccio graduale alla gestione del rischio: la normativa riconosce – secondo una logica c.d. *top-down* – diversi “livelli” di rischio ai quali fa corrispondere differenti obblighi e procedure di segnalazione a carico dei vari operatori, imponendo dunque non solo una valutazione iniziale di potenziale rischio, ma un monitoraggio continuo e costante nel tempo. ⁵

Il testo normativo interessa, dal punto di vista oggettivo, i sistemi di IA – classificati diversamente in base al grado di rischio – immessi nel mercato UE, indipendentemente dal luogo di sviluppo, limitandosi ad escludere alcune categorie di sistemi finalizzati a particolari attività militari o di ricerca. ⁶

La previsione di un'entrata in vigore progressiva delle disposizioni, inoltre, tramite termini di applicazione differenziati, consente sia agli Stati membri che agli operatori destinatari della normativa di ade-

⁴ Pascucci S., *AI Act: la legge europea sull'intelligenza artificiale*, in *Il diritto*, quotidiano Dike, 2025, consultabile al sito: <https://ildiritto.it/professioni-primo-piano/ai-act-la-legge-europea-sullintelligenza-artificiale>.

⁵ Cfr. art. 9 del Regolamento (UE) 2024/1689 (AI Act).

⁶ Cfr. art. 2 del Regolamento (UE) 2024/1689 (AI Act).

guarsi al nuovo quadro normativo: in proposito, il 2 agosto 2026 segnerà l'entrata in vigore integrale del Regolamento, salvo alcune eccezioni; dal 2 agosto 2027 saranno pienamente applicabili tutte le disposizioni relative agli obblighi per i sistemi "ad alto rischio"; ai sensi dell'art. 112, invece, la Commissione Europea potrà periodicamente effettuare modifiche all'elenco dei suddetti sistemi e procedere alla revisione del Regolamento alla luce dell'effettiva incidenza delle sue disposizioni e dei risultati prodotti in sede applicativa.⁷

Questo assetto regolatorio, incentrato su un'implementazione graduale degli obblighi, trova giustificazione nella sua applicazione nei confronti di un'ampia e articolata platea di soggetti che intervengono lungo l'intero ciclo di vita dei sistemi di IA, distinguendo tra fornitori, *deployers* e altri operatori coinvolti nello sviluppo, nella messa a disposizione e nell'utilizzo dei sistemi.

1.1.1

L'AMBITO SOGGETTIVO DELL'AI ACT: FORNITORI, DEPLOYERS E GLI ALTRI SOGGETTI DESTINATARI DELLA DISCIPLINA

La normativa non solo individua una pluralità di soggetti destinatari della disciplina, ma ne definisce i ruoli e i relativi obblighi in funzione delle attività svolte lungo il ciclo di vita dei sistemi di IA.

In particolare, il Regolamento distingue tra fornitori (*providers*), utilizzatori (*deployers*), importatori, distributori, rappresentanti autorizzati e persone interessate che si trovano nell'UE, secondo le definizioni contenute nell'art.3.

Tale articolazione soggettiva riflette l'intento del Legislatore europeo di monitorare il rischio lungo l'intera catena di produzione e utilizzo dell'IA, evitando che esso venga ricondotto esclusivamente al soggetto che ha sviluppato il modello.

All'interno di questo quadro, la distinzione tra *provider* e *deployer* assume un rilievo centrale. La normativa si ri-

⁷ AI Act, in <https://digital-strategy.ec.europa.eu>.

volge al *provider* che sviluppa un sistema o modello di Intelligenza Artificiale e lo immette sul mercato UE,⁸ (art. 2, par. 1, lett. a) e al *deployer* che abbia il proprio luogo di stabilimento o sede all'interno dell'Unione⁹ (art. 2, par. 1, lett. b).

Sono menzionati dalla normativa anche i fornitori che integrano sistemi di IA nei propri prodotti¹⁰ – che immettono nel mercato UE con il proprio nome o marchio commerciale – la cui rilevanza emerge in relazione a determinati settori oggetto di direttive di armonizzazione (art. 2, par. 1, lett. e).

Accanto a tali figure, il Regolamento attribuisce specifici obblighi anche a importatori e distributori¹¹ (art. 2, par. 1, lett. d), in particolare con riferimento alla conformità dei sistemi immessi sul mercato UE, nonché al rappresen-

tante autorizzato¹² del fornitore stabilito al di fuori dell'Unione (art. 2, par. 1, lett. f).

Il testo normativo individua, inoltre, un'ulteriore categoria di soggetti i quali, pur non assumendo un ruolo attivo nello sviluppo o nell'utilizzo dei sistemi di Intelligenza Artificiale, risultano ugualmente destinatari della disciplina in quanto meritevoli di tutela: si tratta delle persone fisiche i cui diritti fondamentali possono essere potenzialmente incisi dall'impiego di sistemi di IA all'interno dell'Unione, indipendentemente dalla loro cittadinanza o dal luogo di stabilimento del fornitore o del *deployer* (art. 2, par. 1, lett. g).

Queste distinzioni soggettive non hanno un valore meramente formale, ma rispondono ad una precisa logica

⁸ Anche fornitori stabiliti fuori dall'UE devono rispettare l'AI Act se immettono i loro prodotti nel mercato europeo.

⁹ Anche se il sistema di IA è stato sviluppato altrove, l'uso che avviene all'interno dell'Unione è sufficiente per far scattare l'applicazione del Regolamento.

¹⁰ In questi casi, il sistema di IA è considerato componente di sicurezza del prodotto, quando l'output del sistema di IA viene utilizzato nell'Unione.

¹¹ Questi soggetti non sono sviluppatori né utilizzatori diretti, ma sono comunque responsabili del rispetto di determinati obblighi di conformità e sorveglianza (artt. 23–25). Il Distributore è il soggetto che compra il sistema di IA e lo rivende a terzi (c.d. messa a disposizione) (vedi art. 3 par. 7). L'importatore è una figura che interviene nel ciclo di vita dei sistemi di intelligenza artificiale ad alto rischio esclusivamente nei casi in cui il fornitore, o il soggetto che appone il marchio commerciale sul sistema, sia stabilito al di fuori dell'Unione europea. Tale soggetto provvede all'immissione del sistema sul mercato dell'Unione, acquistandolo dal fornitore extra-UE, in quanto è colui che, per la prima volta, rende il prodotto disponibile per il consumo o l'uso nel mercato europeo (vedi art. 3 par. 6).

¹² Questa figura è obbligatoria per i fornitori extra-UE (vedi art. 25): garantisce un interlocutore stabile e responsabile nei confronti delle autorità europee.

di gestione del rischio. Il rischio connesso al funzionamento di tali sistemi, infatti, non coincide necessariamente con il controllo tecnico del modello, né si concentra in un unico momento del suo ciclo di vita.

Al contrario, esso si distribuisce lungo la filiera dei diversi operatori, manifestandosi sia nelle fasi di progettazione che di adattamento ed utilizzo concreto del sistema.

Coerentemente con tale impostazione, l'AI Act attribuisce obblighi differenziati – tra cui compiti di valutazione e mitigazione dei rischi, offrendo degli standard cui fare riferimento¹³ – in funzione, da un lato, della posizione occupata dai diversi soggetti all'interno della filiera, dall'altro, dal tipo di sistema in questione.

1.1.2

CLASSIFICAZIONE DEI MODELLI E DEI SISTEMI DI IA

Una prima distinzione concettuale e normativa fondamentale viene introdotta dal Regolamento (UE) 2024/1689 tra sistemi di Intelligenza Artificiale e modelli di Intelligenza Artificiale,¹⁴ snodo essenziale per comprendere la logica della conformità regolatoria e la conseguente distribuzione delle responsabilità lungo il ciclo di vita dell'IA.

Con riferimento al sistema di Intelligenza Artificiale, l'AI Act fornisce una definizione ampia all'art. 3, n. 1, qualificandolo come un sistema automatizzato progettato per operare con diversi livelli di autonomia, in grado di adattarsi al contesto in cui opera e capace di generare *output* quali pre-

¹³ D'Antino V., *L'approccio basato sul rischio nell'AI Act: un nuovo paradigma di regolazione dell'intelligenza artificiale*, 20. La complessità della gestione delle informazioni sui rischi associati ai sistemi di intelligenza artificiale, nonché la pluralità di soggetti coinvolti, ha indotto il legislatore europeo a promuovere l'adozione di standard comuni volti a ridurre gli oneri di conformità. In tale prospettiva, il Regolamento (UE) 2024/1689 favorisce strumenti idonei a semplificare le attività di documentazione, verifica e scambio informativo tra fornitori, deployers e autorità competenti. Un esempio significativo di questo orientamento è rappresentato dall'AI Risk Ontology (AIRO), sviluppata per supportare le organizzazioni nell'adeguamento ai requisiti dell'AI Act e agli standard ISO 31000 in materia di gestione del rischio. Concepite secondo un'impostazione flessibile e adattiva, tali soluzioni sono pensate per mantenere la propria utilità anche in un contesto normativo in evoluzione, offrendo un riferimento operativo stabile per i soggetti destinatari della disciplina. Cfr. Golpayegani D., Pandit H.J., Lewis D., AIRO: An Ontology for Representing AI Risks Based on the Proposed EU AI Act and ISO Risk Management Standards, Dublino, 2022.

¹⁴ Cfr. cons. 97 del Regolamento (UE) 2024/1689 (AI Act): "la nozione di modelli di IA per finalità generali dovrebbe essere chiaramente definita e distinta dalla nozione di sistemi di IA per consentire la certezza del diritto".

visioni, contenuti, raccomandazioni o decisioni che influenzano ambienti fisici o virtuali.

La nozione di sistema si caratterizza per il suo inserimento in un contesto applicativo concreto, nel quale l'IA interagisce con utenti, dati e processi decisionali.

La definizione adottata dalla normativa valorizza una serie di elementi strutturali del sistema: in particolare, la capacità di operare senza un intervento umano continuo, la presenza di gradi di autonomia variabili a seconda della complessità del sistema, l'insieme dei dati di *input* da elaborare e l'infrastruttura tecnica alla base, dai quali dipendono gli effetti giuridicamente rilevanti del sistema stesso.

Diversa è la nozione di modello di Intelligenza Artificiale, introdotta dal Regolamento con riferimento ai “modelli di IA per finalità generale”, che presentino, cioè, le principali caratteristiche “di generalità e di capacità di svolgere con competenza un'ampia gamma di compiti distinti” (art. 3, n. 63; cons. 97).

Il modello di IA viene definito dalla normativa come il risultato di un processo di addestramento su dati, basato su una specifica architettura algoritmica, idoneo a essere integrato in una pluralità di sistemi o applicazioni e a generare *output* diversificati. A differenza del sistema, il modello non è di per sé necessariamente destinato a un uso specifico, ma costituisce quindi una componente tecnica – seppur esistente come entità software autonoma – suscettibile di riutilizzo, adattamento e integrazione in contesti diversi.¹⁵

La distinzione tra modelli e sistemi di IA non ha un rilievo meramente terminologico, ma incide direttamente sugli effetti della disciplina e sulla ripartizione delle responsabilità delineata dall'AI Act. Mentre la pericolosità del sistema è valutata in relazione allo specifico contesto d'uso e agli effetti prodotti, il modello può costituire un centro autonomo di rischio, soprattutto quando venga riutilizzato o modificato da soggetti diversi dal fornitore originario.

In tal senso, il Regolamento riconosce che l'integrazione o la modifica so-

¹⁵ Cfr. cons. 97 del Regolamento (UE) 2024/1689 (AI Act): “sebbene i modelli di IA siano componenti essenziali dei sistemi di IA, essi non costituiscono di per sé sistemi di IA. I modelli di IA necessitano dell'aggiunta di altri componenti, ad esempio un'interfaccia utente, per diventare sistemi di IA. I modelli di IA sono generalmente integrati nei sistemi di IA e ne fanno parte”.

stanziale di un modello può determinare uno spostamento del centro di imputazione degli obblighi, con conseguenze rilevanti sul piano giuridico.

La particolare attenzione riservata ai modelli di Intelligenza Artificiale per finalità generali (*general-purpose AI models*) con rischio sistemico – disciplinati dagli artt. 51 ss. dell'AI Act – si giustifica per la loro elevata capacità di generalizzazione e per la possibilità di essere impiegati in una molteplicità di applicazioni, anche non previste in origine dal fornitore.

Proprio in ragione di tali caratteristiche, il Regolamento prevede per questi modelli un regime di obblighi differenziato rispetto a quello dei sistemi di IA, concentrato prevalentemente su requisiti di trasparenza, documentazione e gestione del rischio, nonché sulla valutazione *ex ante* degli specifici contesti applicativi.

Una volta operata la distinzione tra modello e sistema, la normativa procede a strutturare – come già anticipato – la disciplina della conformità dei sistemi di IA sulla base di un approccio *risk-based*, articolando diversi livelli di rischio.

In particolare, il Regolamento distingue tra pratiche di IA vietate (art. 5), consi-

derate una chiara minaccia per la sicurezza, i mezzi di sussistenza e i diritti fondamentali delle persone e quindi esplicitamente proibite; sistemi di IA ad alto rischio (artt. 6 ss.), in quanto possono comportare rischi significativi per la salute, la sicurezza o i diritti fondamentali; sistemi a rischio limitato (art. 50), soggetti a specifici obblighi di trasparenza e sistemi a rischio minimo o nullo, per lo più esenti da normative stringenti.

La qualificazione di un sistema come «ad alto rischio» segue, ai sensi dell'art. 6, due percorsi alternativi.

Il primo (par. 1) si applica ai sistemi destinati a essere utilizzati come componenti di sicurezza di prodotti coperti dalla normativa di armonizzazione UE elencata nell'Allegato I del Regolamento (dispositivi medici, macchine, giocattoli, ascensori, equipaggiamenti radio, autoveicoli e così via), quando il prodotto è soggetto a valutazione di conformità da parte di terzi.

Il secondo (par. 2) qualifica come ad alto rischio i sistemi impiegati negli ambiti tassativamente individuati dall'Allegato III, fra cui rientrano l'identificazione biometrica e la categorizzazione delle persone fisiche, la gestione delle infrastrutture critiche, l'istruzione e la formazione professionale, l'occupazione

e la gestione dei lavoratori, l'accesso a servizi essenziali pubblici e privati (incluso il *credit scoring*), le attività di *law enforcement*, la migrazione e il controllo delle frontiere, l'amministrazione della giustizia e i processi democratici.

L'art. 6, par. 3, introduce tuttavia un correttivo di proporzionalità: un sistema rientrante nelle aree dell'Allegato III non è considerato ad alto rischio se non presenta un rischio significativo per la salute, la sicurezza o i diritti fondamentali, ovvero se svolge compiti meramente accessori, preparatori o di rilevamento di pattern decisionali umani. La Commissione è inoltre competente, ai sensi dell'art. 7, ad aggiornare l'elenco dell'Allegato III mediante atti delegati. Tale architettura, fondata su criteri tassativi ma dinamicamente aggiornabili, rende la qualifica di «alto rischio» l'esito di una valutazione concreta che incrocia il settore di impiego, la finalità del sistema e l'incidenza sui diritti fondamentali.

Nel complesso, è rilevante sottolineare che tale classificazione è funzionale all'imposizione di obblighi graduati di conformità e prevenzione, anche in virtù dei potenziali effetti pregiudizievoli del sistema, ma non è finalizzata

alla disciplina dell'impatto economico del danno eventualmente prodotto. Il Regolamento, infatti, si concentra sulla gestione preventiva del rischio e sulla conformità dei sistemi, lasciando totalmente impregiudicata la regolazione delle conseguenze risarcitorie.

Proprio questa scelta di fondo, che separa la disciplina della conformità dalla regolazione delle conseguenze patrimoniali del danno, rende centrale l'analisi dei meccanismi attraverso i quali il rischio e le responsabilità vengono allocati tra i diversi soggetti coinvolti e degli obblighi a loro attribuiti.

1.1.3

OBBLIGHI DI GESTIONE DEL RISCHIO, TRASPARENZA E ACCOUNTABILITY

L'AI Act introduce un sistema organico di obblighi finalizzati a garantire un elevato livello di gestione del rischio, trasparenza e *accountability* lungo l'intero ciclo di vita dei sistemi, indirizzati a ciascuna delle figure prese in considerazione dalla normativa.¹⁶

¹⁶ Conditì N., *I soggetti coinvolti dall'AI ACT: uno sguardo d'insieme*, 2024, consultabile al sito: <https://www.studiolegalestefanelli.it>.

Il fulcro della disciplina è rappresentato dagli obblighi posti in capo ai fornitori, ai sensi degli articoli 16 e ss. del Regolamento, i quali sono tenuti a immettere sul mercato o mettere in servizio esclusivamente sistemi conformi ai requisiti tecnici stabiliti dal Capo III, Sezione 2.

Tali requisiti includono principalmente l'adozione di un sistema di gestione del rischio, la qualità e *governance* dei dati, la documentazione tecnica, la trasparenza, la supervisione umana, nonché adeguati livelli di accuratezza, robustezza e cybersicurezza.

In questa prospettiva, il fornitore deve essere chiaramente identificabile e deve istituire un sistema di gestione della qualità conforme all'art. 17, che sia idoneo a garantire il controllo continuo della conformità normativa.

Centrale è, inoltre, l'obbligo di predisporre e conservare la documentazione tecnica (art. 18) e i *log* automatici generati dal sistema (art. 19), strumenti essenziali ai fini della tracciabilità e della verificabilità delle decisioni automatizzate.

Prima dell'immissione sul mercato, il sistema deve essere sottoposto a una procedura di valutazione di conformità ai sensi dell'art. 43, cui seguono la redazione della dichiarazione UE di confor-

mità (art. 47), l'apposizione della marcatura CE (art. 48) e la registrazione nella banca dati europea dei sistemi di IA ad alto rischio (art. 49).

Il Regolamento prevede inoltre obblighi di intervento attivo in caso di non conformità, imponendo al fornitore l'adozione di misure correttive, nonché obblighi informativi verso le autorità competenti e gli altri operatori della catena di fornitura (art. 20), rafforzando così il principio di *accountability*.

Obblighi analoghi si applicano anche ai fornitori che integrano sistemi di IA ad alto rischio all'interno dei propri prodotti, i quali, come già anticipato, assumono la responsabilità della conformità del sistema integrato.

Accanto ai fornitori, un ruolo fondamentale è attribuito ai *deployers*.

L'art. 26 stabilisce che essi debbano utilizzare i sistemi in conformità alle istruzioni d'uso, garantire una supervisione umana qualificata, assicurare la qualità dei dati di *input* sotto il loro controllo e monitorare costantemente il funzionamento del sistema, sospendendone l'uso in caso di rischio per la salute, la sicurezza o i diritti fondamentali e informando il fornitore o distributore e la pertinente autorità di vigilanza.

A ciò si aggiungono obblighi di conservazione dei *log*, di informazione nei confronti dei lavoratori e delle persone fisiche interessate, di cooperazione con le autorità competenti e, nei casi previsti, di registrazione del sistema nella banca dati UE. Particolarmente rilevante è inoltre l'obbligo di svolgere una valutazione di impatto sui diritti fondamentali ai sensi dell'art. 27, che rafforza l'approccio preventivo e *human-centric* della normativa.

L'AI Act disciplina, poi, gli obblighi di altri soggetti della catena del valore, quali importatori, distributori e rappresentanti autorizzati, cui è richiesto di verificare e preservare la conformità dei sistemi, e riconosce anche specifiche tutele alle persone interessate dall'uso dell'IA.

L'importatore è tenuto, prima dell'immissione sul mercato, ad assicurarsi che il sistema sia conforme al Regolamento verificando l'esecuzione della valutazione di conformità, la preparazione della documentazione tecnica, la presenza della marcatura CE e della dichiarazione di conformità UE, nonché la nomina di un rappresentante autorizzato. Deve, inoltre, indicare i propri dati identificati-

vi sul sistema o sulla documentazione, garantire che le condizioni di trasporto e stoccaggio non compromettano la conformità, conservare determinati documenti per almeno 10 anni e cooperare con le autorità competenti (Art. 23).

Il distributore, a sua volta, prima di rendere disponibile un sistema ad alto rischio sul mercato, deve verificare che il prodotto rechi la marcatura CE, sia accompagnato dalla dichiarazione di conformità UE e dalle istruzioni per l'uso, e che il fornitore e l'importatore abbiano adempiuto ai propri obblighi. In caso di rischio o non conformità accertata, il distributore deve immediatamente informare il fornitore o l'importatore e le autorità competenti, fornendo le relative informazioni e cooperando con tali autorità (Art. 24).

Il rappresentante autorizzato, invece, nominato dal fornitore extra-UE, è incaricato di verificare che il fornitore abbia predisposto la documentazione tecnica richiesta e adempiuto agli obblighi applicabili, di mantenere la documentazione a disposizione delle autorità per un certo periodo,¹⁷ di fornire informazioni su richiesta e di cooperare con le auto-

¹⁷ Cfr. art. 22 del Regolamento (UE) 2024/1689 (AI Act): il rappresentante è tenuto a conservare per 10 anni dopo la data di immissione in commercio: i dati di contatto del fornitore; copia della dichiarazione di conformità UE; documentazione tecnica; certificato CE (se presente).

rità competenti nell'ambito delle attività di vigilanza e conformità, compresa la comunicazione della cessazione del mandato se il fornitore agisce in violazione degli obblighi normativi (Art. 22).

Infine, l'Articolo 25 disciplina la responsabilità "a catena": importatori, distributori, *deployers* o altri terzi possono essere considerati come *provider* di un sistema ad alto rischio e soggetti agli obblighi dell'art. 16 qualora appongano il proprio nome o marchio sul sistema, apportino modifiche sostanziali o ne alterino la destinazione d'uso, rendendo il sistema stesso ad alto rischio.

La definizione di «modifica sostanziale» è offerta dall'art. 3, n. 23, e richiede una variazione non prevista dal fornitore originario nella sua valutazione di conformità che incida sulla rispondenza ai requisiti del Capo III, Sezione 2, ovvero sulla destinazione d'uso. Si tratta di una nozione destinata ad assumere centralità soprattutto rispetto ai modelli di IA per finalità generali, soggetti a *fine-tuning*,

riaddestramento o specializzazione da parte di soggetti diversi dal *provider* originario: in tali ipotesi il *deployer* può trasformarsi, sul piano regolatorio, in fornitore di un sistema ad alto rischio, con conseguente assunzione degli obblighi di documentazione tecnica, gestione della qualità, valutazione di conformità e marcatura CE.

Di particolare rilievo è il paragrafo 4 dell'art. 25, che chiarisce come la ripartizione degli obblighi tra i diversi operatori possa essere oggetto di accordi contrattuali, fermo restando il rispetto degli obblighi inderogabili previsti dal Regolamento.

In questo contesto, assume un ruolo centrale la possibilità, delineata dalla normativa, che l'Ufficio per l'IA¹⁸ promuova o faciliti l'elaborazione di clausole contrattuali tipo, funzionali a garantire un'allocazione chiara e coerente delle responsabilità lungo la catena del valore, rafforzando la certezza giuridica per gli operatori senza incidere sul nucleo co-

¹⁸ Cfr. art. 64 del Regolamento (UE) 2024/1689 (AI Act): l'articolo 64 istituisce presso la Commissione europea l'Ufficio per l'IA, attribuendogli funzioni di coordinamento, supporto e vigilanza nell'attuazione del Regolamento, con particolare riferimento ai sistemi di IA e ai modelli di IA di uso generale. Tra i suoi compiti rientrano, oltre al monitoraggio dell'applicazione uniforme dell'AI Act e al supporto alle autorità nazionali competenti, anche attività di indirizzo regolatorio e *soft law*, quali la predisposizione di orientamenti, raccomandazioni e strumenti di supporto alla conformità. In tale prospettiva, l'Ufficio per l'IA assume un ruolo centrale anche nel favorire la standardizzazione delle pratiche contrattuali, inclusa la possibile elaborazione o promozione di clausole contrattuali tipo, funzionali a una corretta allocazione delle responsabilità lungo la catena del valore dell'IA, ferma restando l'inderogabilità degli obblighi sostanziali previsti dal Regolamento.

gente degli obblighi di conformità, trasparenza e *accountability* fissati dall'AI Act.

Per i sistemi non qualificati come ad alto rischio, il Regolamento prevede invece un regime più flessibile, incentrato prevalentemente su obblighi di trasparenza e informazione.

In linea generale, tali sistemi non sono soggetti ai requisiti stringenti del Capo III, Sezione 2, ma restano comunque assoggettati a specifici obblighi orizzontali.

In primo luogo, assumono rilievo gli obblighi di trasparenza previsti dall'art. 50 del Regolamento, applicabili ai c.d. sistemi "a rischio limitato".

In particolare, quando un sistema di IA interagisce direttamente con una persona fisica (ad esempio *chatbot* o assistenti virtuali), il *deployer* deve informare chiaramente l'utente che sta interagendo con un sistema di IA (art. 50, par. 1).

Analoghi obblighi informativi sono previsti per i sistemi di riconoscimento delle emozioni, di categorizzazione biometrica e per i sistemi che generano o manipolano contenuti audio, visivi o audiovisivi (c.d. *deepfake*), rispetto ai quali è richiesto che il contenuto sia chiaramente etichettato come artificialmente generato o alte-

rato (art. 50, parr. 2–4), salvo specifiche eccezioni.

Per i sistemi che non rientrano né tra quelli vietati né tra quelli a rischio alto o limitato, il Regolamento configura un'area di rischio minimo, nella quale non sono imposti obblighi giuridicamente vincolanti *ex ante*.

Tuttavia, l'art. 95 incoraggia in ogni caso fornitori e *deployers* ad adottare codici di condotta volontari, volti a promuovere l'applicazione dei principi generali dell'AI Act – quali affidabilità, equità, supervisione umana e sicurezza – anche al di fuori dei casi formalmente regolati.

Resta fermo che anche i sistemi non ad alto rischio sono soggetti agli obblighi generali di cooperazione con le autorità competenti, nonché al rispetto della normativa UE applicabile *ratione materiae* (ad es. GDPR, tutela dei consumatori, sicurezza dei prodotti).

Inoltre, qualora un sistema inizialmente non ad alto rischio venga modificato o utilizzato in modo tale da rientrare nelle fattispecie dell'allegato III, potrà trovare applicazione il regime più stringente previsto per i sistemi ad alto rischio, secondo la logica dinamica del Regolamento.



La Direttiva NIS2: finalità e novità introdotte rispetto alla NIS1

La Direttiva (UE) 2022/2555 (NIS2 – Network and Information Security) persegue l'obiettivo di conseguire un livello elevato e comune di cybersicurezza nell'Unione, come espressamente indicato all'art. 1, rafforzando e superando l'impianto della precedente Direttiva (UE) 2016/1148 (NIS1), attraverso l'estensione dell'ambito di applicazione, la definizione di requisiti normativi più puntuali e strumenti di vigilanza più solidi.¹⁹

La Direttiva impone a ciascuno Stato membro un approccio sistematico alla gestione del rischio di sicurezza informatica, che, al fine di rafforzare la resilienza digitale delle infrastrutture

critiche e dei servizi essenziali, si traduce nell'adozione di misure idonee a prevenire e mitigare vulnerabilità quali la manipolazione dei dati di addestramento, gli attacchi ai modelli e l'uso improprio degli *output* automatizzati.

Recepita nell'ordinamento italiano mediante il D.Lgs. n. 138/2024 – pubblicato nella Gazzetta Ufficiale il 1° ottobre 2024 ed entrato in vigore il 16 ottobre 2024 – la Direttiva consente un periodo transitorio volto a consentire alle imprese di adeguarsi progressivamente ai nuovi obblighi.²⁰

Un elemento di forte novità rispetto alla NIS1 è l'ampliamento del numero

¹⁹ Maggiori informazioni al sito: <https://digital-strategy.ec.europa.eu/it/policies/nis2-directive>.

²⁰ Tutto quello che devi sapere sulla normativa NIS 2 (2025), consultabile al sito: <https://www.intesa.it>.

di settori e aziende soggetti alla normativa oltre che l'estensione degli obblighi di sicurezza all'intera catena di approvvigionamento.

La NIS2 rafforza, inoltre, gli obblighi di notifica degli incidenti informatici, introducendo un *iter* articolato in tre fasi: una pre-notifica entro 24 ore dall'individuazione dell'incidente significativo; una notifica con valutazione iniziale di gravità e impatto entro 72 ore; una relazione finale dettagliata entro un mese dalla notifica (art. 23).

La Direttiva richiede anche l'adozione di piani di continuità operativa e di gestione delle crisi, essenziali per garantire la continuità dei servizi in caso di attacchi o malfunzionamenti.

Ulteriori requisiti riguardano l'esecuzione di test e valutazioni periodiche delle misure di sicurezza,²¹ nonché l'implementazione di controlli di accesso rigorosi e soluzioni di autenticazione multi-fattore per la protezione dei sistemi (art. 21).

La NIS2 valorizza inoltre la formazione continua del personale, la protezione dei dati tramite tecniche crittografi-

che e la cooperazione tra organizzazioni e autorità competenti per la condivisione di informazioni su minacce e incidenti legati anche all'uso dell'IA.

Rispetto alla NIS1, la Direttiva introduce infine un sistema di supervisione e sanzioni più severo, con sanzioni amministrative pari a "un massimo di almeno 10 milioni di euro o ad un massimo di almeno il 2% del fatturato mondiale annuo per l'esercizio precedente dell'impresa cui il soggetto essenziale appartiene se tale importo è superiore", sottolineando il ruolo centrale della sicurezza dei sistemi di IA nel nuovo ecosistema digitale europeo (art.34).

1.2.1

L'AMBITO SOGGETTIVO DELLA NIS2: SOGGETTI E SETTORI INTERESSATI

L'art. 2 della Direttiva (UE) 2022/2555 definisce l'ambito di applicazione della NIS2, introducendo una distinzione fondamentale tra soggetti essenziali e soggetti importanti, ulteriormen-

²¹ La direttiva non impone standard specifici, ma legittima l'uso di *framework* internazionali come *best practice*, quali il NIST SP 800-115, l'OSSTMM e le linee guida OWASP.

te precisata dall'art. 3 e dagli allegati I e II, nei quali sono elencati, rispettivamente, i settori ad alta criticità e gli altri settori critici.

Diversamente dalla NIS1, la nuova Direttiva adotta, quindi, un approccio prevalentemente dimensionale e settoriale, fondato sul superamento delle soglie previste per le medie imprese ai sensi della raccomandazione 2003/361/CE, superando così il modello basato sull'individuazione discrezionale degli operatori di servizi essenziali da parte degli Stati membri.

Sono qualificati come soggetti essenziali, ai sensi dell'art. 3 della Direttiva, in primo luogo i soggetti operanti nei settori ad alta criticità di cui all'allegato I che superano i massimali dimensionali previsti per le medie imprese dall'art. 2, par. 1, dell'allegato alla raccomandazione 2003/361/CE; a tale categoria si affiancano, indipendentemente dalla dimensione, taluni operatori ritenuti intrinsecamente critici per il funzionamento delle infrastrutture digitali e dei mercati, quali i prestatori di servizi fiduciari qualificati e registri dei nomi di dominio di primo livello, i fornitori di servizi DNS, nonché i fornitori di reti pubbliche di comunicazione elettronica o di servizi

di comunicazione elettronica accessibili al pubblico.

Rientrano, inoltre, tra i soggetti essenziali specifiche entità della pubblica amministrazione: in particolare le amministrazioni centrali e, ove previsto dal diritto nazionale, le amministrazioni regionali, secondo le definizioni adottate dai singoli Stati membri.

La Direttiva attribuisce, altresì, agli Stati membri un margine di discrezionalità nell'individuazione di ulteriori soggetti come essenziali, includendo qualsiasi entità di cui agli allegati I o II che, in ragione della propria rilevanza sistemica o del contesto nazionale, sia qualificata come tale ai sensi dell'art. 2, par. 2, lett. da b) a e).

A completamento del quadro, sono considerati soggetti essenziali anche quelli identificati come soggetti critici ai sensi della Direttiva (UE) 2022/2557 (CER), nonché, qualora lo Stato membro lo preveda, gli operatori precedentemente designati come operatori di servizi essenziali ai sensi della Direttiva (UE) 2016/1148 (NIS1) o della normativa nazionale, prima del 16 gennaio 2023.

I soggetti importanti, ai sensi dell'art. 3 della NIS2, sono invece individuati in via residuale e comprendono tutte le

entità operanti in una delle tipologie elencate negli allegati I o II che non rientrano nella categoria dei soggetti essenziali.

Pur essendo assoggettati a un regime di vigilanza meno intenso, tali soggetti restano destinatari di obblighi significativi in materia di gestione del rischio di cybersicurezza e di notifica degli incidenti, in considerazione della loro potenziale incidenza sul funzionamento dell'economia e della società.

Infatti, la distinzione tra soggetti essenziali e soggetti importanti non ha natura meramente classificatoria, ma risponde a una logica di regolazione del rischio proporzionata, come chiarito dal considerando 82 della Direttiva.

In particolare, i regimi di vigilanza e di esecuzione sono differenziati al fine di garantire un equilibrio tra l'intensità degli obblighi di sicurezza e gli oneri amministrativi gravanti sui destinatari, tenendo conto di fattori quali la criticità del soggetto e la probabilità e la gravità degli incidenti, adattando le misure di gestione del rischio di cybersicurezza alla natura, alle dimensioni

e al grado di esposizione al rischio dei singoli operatori, ed evitando un'applicazione uniforme che potrebbe risultare sproporzionata o inefficace.

Dal punto di vista settoriale, l'allegato I individua quelli ad alta criticità, tra cui figurano, in particolare, l'energia, i trasporti, il settore bancario e finanziario, la sanità, le infrastrutture digitali, i gestori di servizi TIC ²² e lo spazio; ambiti nei quali eventuali compromissioni dei sistemi informativi, inclusi quelli basati su Intelligenza Artificiale, possono produrre effetti sistemici su larga scala.

L'allegato II elenca, invece, gli altri settori critici, quali i servizi postali, la gestione dei rifiuti, la produzione alimentare, la manifattura, i fornitori di servizi digitali e la ricerca, che, pur presentando un livello di esposizione al rischio generalmente inferiore, risultano comunque vulnerabili ad attacchi informatici con potenziali ripercussioni significative sul funzionamento della società e dell'economia.

L'eterogeneità dei settori e dei sottosettori individuati dalla NIS2 rende necessario un coordinamento con numerose normative speciali dell'U-

²² Tecnologie dell'Informazione e della Comunicazione.

nione europea, richiamate indirettamente dalla Direttiva, al fine di garantire una corretta identificazione degli ambiti di applicazione.

Il sistema delineato dalla NIS2 si inserisce, infine, in un più ampio assetto istituzionale di cooperazione e vigilanza, che coinvolge diversi attori a livello nazionale ed europeo.

In particolare, ogni Stato membro designa un CSIRT ²³ nazionale quale punto di riferimento per la gestione e la risposta agli incidenti informatici; a livello dell'Unione opera il Gruppo di cooperazione NIS, composto dai rappresentanti degli Stati membri, della Commissione europea e dell'ENISA, ²⁴ con funzioni di coordinamento strategico; mentre, in caso di incidenti o attacchi informatici su larga scala che coinvolgano più Stati membri, è prevista l'attivazione della rete CyCLONe, ²⁵ volta a garantire una risposta coordinata alle crisi cibernetiche.

Tale architettura rafforza l'efficacia dell'ambito soggettivo della Direttiva, assicurando che l'estensione degli obblighi di sicurezza sia accompagnata

da adeguati strumenti di supporto, cooperazione e supervisione.

1.2.2

GESTIONE DEL RISCHIO, *SUPPLY CHAIN* E POLITICA DELLO “ZERO TRUST”

Il nucleo centrale della Direttiva (UE) 2022/2555, come anticipato, è rappresentato dagli obblighi di gestione del rischio di cybersicurezza previsti dall'art. 21, che impone ai soggetti essenziali e ai soggetti importanti l'adozione di misure tecniche, operative e organizzative adeguate e proporzionate al livello di rischio cui sono esposti i loro sistemi informativi e di rete.

La Direttiva supera una concezione meramente reattiva della sicurezza informatica, introducendo un modello di *risk management* continuo, fondato sulla prevenzione, sulla resilienza e sulla capacità di risposta e recupero in caso di incidente.

Per tale ragione, particolare impor-

²³ Computer Security Incident Response Team.

²⁴ Agenzia dell'Unione Europea per la Cybersicurezza.

²⁵ Cyber Crisis Liaison Organisation Network.

tanza è attribuita alla sicurezza della *supply chain* e ai rapporti con i fornitori, espressamente richiamata dall'art. 21, par. 2, lett. d), che impone di tenere conto dei rischi derivanti dalla dipendenza da soggetti terzi e dalla qualità complessiva dei prodotti e dei servizi TIC utilizzati.

La norma richiede una valutazione sistematica delle vulnerabilità lungo l'intera catena di approvvigionamento, includendo non solo i fornitori diretti, ma anche, ove rilevante, i subfornitori e gli altri operatori coinvolti nell'erogazione dei servizi essenziali o importanti. Tale approccio è rafforzato dall'obbligo di considerare le pratiche di sviluppo sicuro, la gestione delle vulnerabilità, la sicurezza nella manutenzione dei sistemi e le misure di continuità operativa, *disaster recovery* e backup.²⁶

Questa impostazione normativa riflette una logica sostanzialmente ri-

conducibile al paradigma dello “Zero Trust”, sebbene tale espressione sia menzionata dalla Direttiva solo al considerando 89, senza ulteriore definizione o specificazione nel corpo del testo normativo.

La NIS2 presuppone, infatti, che nessun componente dell'ecosistema digitale — interno o esterno all'organizzazione — possa essere considerato affidabile in via presuntiva, richiedendo controlli continui, verifiche periodiche e meccanismi di limitazione del rischio basati sul principio del minimo privilegio e sulla segmentazione delle responsabilità. La fiducia viene così sostituita da processi strutturati di verifica e monitoraggio, che si estendono a tutta la filiera tecnologica.

In questo quadro, la contrattualizzazione dei rapporti con i fornitori di tecnologie digitali, inclusi quelli che sviluppano, integrano o forniscono

²⁶ La Direttiva richiede ai soggetti essenziali e importanti l'adozione di misure tecniche e organizzative idonee a garantire la disponibilità, l'integrità, l'autenticità e la riservatezza dei sistemi informativi e di rete, nonché la capacità di ripristinare tempestivamente i servizi essenziali in caso di incidente di cibersicurezza. In tale prospettiva, i backup assumono un ruolo centrale quale strumento di resilienza operativa, dovendo essere adeguatamente protetti, periodicamente testati e, ove necessario, segregati rispetto ai sistemi di produzione, al fine di prevenire fenomeni di compromissione simultanea; la continuità operativa è configurata non come misura meramente emergenziale, ma come componente strutturale della gestione del rischio di cibersicurezza, da integrare stabilmente nei processi organizzativi e decisionali dell'ente e da mantenere aggiornata nel tempo; l'adozione di piani di *disaster recovery* formalizzati è volta a contrastare la perdita di dati, tramite l'individuazione di obiettivi di ripristino (RTO e RPO), la predisposizione di infrastrutture e procedure alternative, nonché lo svolgimento di test e simulazioni periodiche volti a verificarne l'effettiva efficacia.

sistemi di IA, assume un ruolo strategico.

Pur non disciplinando direttamente il contenuto dei contratti, la NIS2 ne valorizza implicitamente la funzione quale strumento di attuazione concreta degli obblighi di sicurezza.

Attraverso le clausole contrattuali, i soggetti obbligati sono chiamati a tradurre i requisiti normativi in impegni giuridicamente vincolanti, prevedendo, come già detto, obblighi in materia di livelli di sicurezza, *audit* e verifiche ispettive, gestione e notifica degli incidenti, cooperazione con le autorità competenti, obblighi informativi tempestivi e diritti di intervento o di risoluzione del rapporto in caso di rischio grave per la sicurezza dei sistemi.

La centralità della *supply chain* nella NIS2 contribuisce, inoltre, a delineare una responsabilità estesa lungo la catena del valore, che mira ad evitare che le vulnerabilità di un singolo fornitore possano compromettere l'intero ecosistema.

Tale impostazione non persegue un'automatica esternalizzazione della responsabilità, ma impone ai soggetti essenziali e importanti un

ruolo attivo nella selezione, nel controllo e nella *governance* dei partner tecnologici.

In questa prospettiva, la NIS2 sembra anticipare e rafforzare una convergenza sistemica con il futuro quadro regolatorio dell'Intelligenza Artificiale e in particolare con l'AI Act che, analogamente, adotta una logica di responsabilizzazione multilivello lungo il ciclo di vita di tali sistemi.

L'effettività delle previsioni dell'art. 21 della NIS2 è progressivamente rafforzata dagli atti di esecuzione adottati dalla Commissione europea.

In particolare, il Regolamento di esecuzione (UE) 2024/2690 del 17 ottobre 2024 specifica, per un primo nucleo di soggetti (fornitori di servizi DNS, registri di nomi di dominio di primo livello, fornitori di servizi *cloud* e di *data center*, reti di distribuzione di contenuti, fornitori di servizi gestiti e di servizi di sicurezza gestiti, *marketplace*, motori di ricerca, piattaforme di *social network* e prestatori di servizi fiduciari), i requisiti tecnici e metodologici delle misure di gestione del rischio nonché i criteri di significatività degli incidenti ai sensi dell'art. 23 della Direttiva.

L'allegato al Regolamento articola i requisiti in tredici aree, fra cui assumono particolare rilievo, ai fini della presente trattazione, quelle relative alla sicurezza della *supply chain* (art. 21, par. 2, lett. d) NIS2) e alla sicurezza nell'acquisizione, sviluppo e manutenzione dei sistemi informativi (lett. e), e si fonda dichiaratamente, ai sensi del considerando 3, sui principali standard internazionali (ISO/IEC 27001, ISO/IEC 27002, ETSI EN 319/401).

Sul piano dell'attuazione operativa, la guida tecnica elaborata dall'ENISA in collaborazione con la Commissione europea e con il Gruppo di Cooperazione NIS, pur priva di efficacia vincolante, fornisce indicazioni dettagliate per l'implementazione dei requisiti del Regolamento di esecuzione, accompagnate da esempi pratici e da tabelle di mappatura rispetto agli standard europei e internazionali.

Si tratta di uno strumento di *soft law* destinato a orientare in via uniforme l'attività di vigilanza delle autorità nazionali competenti e, di riflesso, le politiche di *compliance* degli operatori. La progressiva sedimentazione di tali fonti di esecuzione e di indi-

rizzo conferma la traiettoria evolutiva della NIS2 verso una disciplina sostanzialmente armonizzata della sicurezza informatica, nella quale la cornice direttoriale è completata da regole tecniche dettagliate e da prassi attuative comuni, idonee a ridurre i margini di discrezionalità nazionale e a rafforzare la protezione lungo la catena di fornitura digitale.



Interazioni tra AI Act e NIS2 nella disciplina dei modelli di IA

L'interazione tra l'AI Act e la NIS2 non si esaurisce in una mera giustapposizione di obblighi, ma delinea un quadro integrato di governo del rischio tecnologico che incide in modo diretto sulla disciplina del mondo dell'IA.

Le due normative operano su piani distinti, ma convergenti: l'AI Act interviene sul sistema di IA in quanto tale, mentre la NIS2 regola la sicurezza dell'ecosistema digitale e organizzativo in cui tale sistema è sviluppato, integrato e utilizzato.

Come analizzato, l'AI Act si fonda su una logica di prevenzione *ex ante*, imponendo requisiti volti a garantire sicurezza, affidabilità, tracciabilità e ri-

spetto dei diritti fondamentali lungo l'intero ciclo di vita del sistema.

La gestione del rischio, la qualità dei dati, la documentazione tecnica e i meccanismi di *log* non sono meri adempimenti formali, ma strumenti di controllo sostanziale sulla capacità del sistema di produrre decisioni verificabili e governabili.

L'attenzione non è rivolta soltanto alla dimensione tecnica, bensì anche alla qualità delle decisioni automatizzate, affrontando il rischio – meno visibile ma potenzialmente più incisivo – di processi opachi o non controllabili.²⁷

La NIS2, per contro, assume come og-

²⁷ Bacini M., *Da protezione a resilienza: cosa cambia con NIS2 e AI Act in azienda*, in *agendadigitale.eu*, 2026.

getto primario la resilienza operativa dei soggetti pubblici e privati che erogano servizi essenziali o importanti.

Il suo baricentro è rappresentato dalla gestione degli incidenti, dalla sicurezza della *supply chain*, dalla continuità dei servizi e dalla capacità di ripristino.

In questa prospettiva, la sicurezza non coincide con l'assenza di attacchi, ma con la capacità dell'organizzazione di assorbire l'imprevisto, reagire, mantenere il controllo e ripristinare le proprie funzioni critiche.

È proprio nei modelli di IA – in particolare quelli generativi o integrati in servizi ad alta criticità – che le due discipline trovano un punto di convergenza naturale. Un malfunzionamento di un sistema di Intelligenza Artificiale può costituire, al tempo stesso, una violazione dei requisiti sostanziali previsti dall'AI Act e un incidente di sicurezza ai sensi della NIS2, qualora comprometta la disponibilità, l'integrità o la riservatezza dei sistemi informativi o la continuità del servizio.

La distinzione tra “errore algoritmico” e “incidente cyber” tende così ad attenuarsi, imponendo una gestione coordinata dei meccanismi di prevenzione, rilevazione e notifica.

Ne deriva una complementarità strutturale: l'AI Act definisce ciò che un sistema di IA deve garantire per essere lecito e affidabile; la NIS2 stabilisce come debba essere protetto l'ambiente tecnologico e organizzativo in cui quel sistema opera.

Se il primo regola la qualità e la *governance* del modello, la seconda disciplina la sicurezza dell'infrastruttura, delle interconnessioni e della catena di fornitura.

Non si tratta di una duplicazione normativa, bensì di un doppio livello di tutela che agisce, rispettivamente, sulla dimensione funzionale e su quella infrastrutturale del rischio.

Tale assetto produce effetti rilevanti sui soggetti della filiera dell'IA.

Un *provider* può essere destinatario degli obblighi dell'AI Act in quanto fornitore di un sistema regolato e, contemporaneamente, rientrare nell'ambito applicativo della NIS2 come operatore critico o come elemento significativo della *supply chain*.

Analogamente, un *deployer* – ad esempio una pubblica amministrazione o un'impresa qualificata come soggetto essenziale – è tenuto a garantire sia l'uso conforme del sistema

secondo l'AI Act, sia la sicurezza e la resilienza dell'infrastruttura ai sensi della NIS2.

Si configura così una responsabilità distribuita, multilivello, che non sempre però trova una delimitazione puntuale nella normativa e che, nella prassi, può dare vita ad ipotesi di responsabilità di difficile interpretazione.

Entrambe le discipline manifestano una convergente attenzione verso la gestione consapevole delle dipendenze tecnologiche, divenute elemento fisiologico delle infrastrutture digitali contemporanee.

Modelli di IA, servizi *cloud*, piattaforme digitali e fornitori terzi non rappresentano più componenti accessorie, ma snodi strutturali dell'ecosistema operativo di imprese e pubbliche amministrazioni.

L'intervento dell'ordinamento europeo non è orientato a sopprimere tali interconnessioni, bensì a sottoporle a un regime di trasparenza, valutazione e governo del rischio.

Con questa chiave di lettura, la sicurezza non si identifica con l'autosuffi-

cienza tecnologica, ma con la capacità di attenuare le asimmetrie informative e decisionali che possono emergere nel rapporto tra utilizzatore e fornitore della tecnologia.²⁸

L'attuazione congiunta di AI Act e NIS2 comporta, tuttavia, sfide significative: l'esigenza di armonizzazione tra Stati membri, il coordinamento dei meccanismi di *reporting* per incidenti *cyber* e per incidenti legati all'IA, l'impatto organizzativo e la crescente domanda di competenze specialistiche.

Il rischio è che l'adempimento si traduca in un mero incremento della documentazione senza un effettivo rafforzamento della capacità operativa.²⁹

²⁸ Bacini M., *op. cit.*

²⁹ Serafini G., *NIS2 & AI Act: "Stato di attuazione in UE, sinergie e sfide"*, in *cipslegal.it*, 2024.



Profili di responsabilità emergenti dal quadro normativo europeo

Il quadro normativo europeo contemporaneo presenta, accanto ad un sistematico rafforzamento degli obblighi di prevenzione e di sicurezza, significative fragilità concettuali sul piano della responsabilità dei soggetti coinvolti nell'ecosistema dei sistemi di IA. Nell'interazione fra AI Act e Direttiva NIS2, emergono in modo particolare alcune zone grigie che riflettono limiti e ambiguità nella disciplina della responsabilità, soprattutto in assenza di una normativa unitaria sulla responsabilità civile specifica per l'Intelligenza Artificiale.³⁰

Una prima zona grigia riguarda il rapporto tra responsabilità regolatoria e responsabilità materiale nei casi di danno.

L'AI Act, pur delineando principi di gestione del rischio, requisiti di trasparenza e tracciabilità e obblighi di vigilanza umana, non prevede una disciplina diretta della responsabilità civile per danni causati da sistemi di IA: la responsabilità per il danno, nel diritto vigente, continua ad essere inquadrata nei tradizionali paradigmi di colpa, nesso causale e prevedibilità, che appaiono difficilmente applicabili a fenomeni algoritmici complessi e autonomi.

Ciò genera incertezze sull'attribuzione del danno e sulla dimostrazione del nesso causale fra condotta e danno, specie in relazione a sistemi opachi e di *machine learning* che operano "in autonomia".

³⁰ *Responsabilità Civile e Intelligenza Artificiale: Il Nuovo Rischio Invisibile*, 2025, consultabile al sito: <https://www.lexopera.it>.

Dal lato della Direttiva NIS2, la disciplina della responsabilità si concentra sui doveri di governance e di sicurezza, attribuendo agli organi di gestione la responsabilità di assicurare adeguate misure organizzative e tecniche e la gestione degli incidenti.

Tuttavia, la NIS2 non disciplina direttamente chi sia responsabile per i danni derivanti da un incidente ai sensi della normativa civile o amministrativa interna: essa impone obblighi di prevenzione, notifica e risposta agli incidenti, ma lascia alla normativa nazionale e alla giurisprudenza il compito di tradurre tali eventi in responsabilità risarcitoria effettiva.

Questo quadro può generare un disallineamento tra l'accertamento di una violazione della NIS2 e la sua traduzione in responsabilità giuridica per il danno. Tali zone grigie emergono con particolare evidenza soprattutto nei contesti in cui il sistema di IA è il risultato di una filiera complessa: modelli sviluppati da un operatore, adattati o perfezionati da un altro, ospitati su piattaforme cloud di terzi e impiegati da un *deployer* che li integra nei propri processi decisionali. In queste ipotesi, seppur il quadro normativo europeo cerchi di razionalizzare gli obblighi in capo a tutti i vari soggetti facenti parte della filiera, la distinzione tra difetto originario del

sistema, errore di configurazione, vulnerabilità dell'infrastruttura o uso non conforme può risultare sfumata. La frammentazione funzionale degli obblighi regolatori non coincide necessariamente con una chiara frammentazione della responsabilità civile.

Un'ulteriore inconsistenza riguarda la coerenza delle figure giuridiche tra le due normative. L'AI Act distingue ruoli come *provider*, *deployer*, importatore, rappresentante e distributore di sistemi di IA, con obblighi differenziati in funzione del ruolo ricoperto; la NIS2 utilizza invece la distinzione tra soggetti essenziali e importanti, fondata su criteri settoriali e dimensionali. Benché le due normative – come si è avuto modo di analizzare – siano destinate a coesistere anche dal punto di vista dell'ambito di applicazione soggettivo, questa diversità di criteri può portare talvolta a situazioni in cui un medesimo operatore risulti responsabile ai fini dell'AI Act ma non qualificato come soggetto obbligato ai fini della NIS2, o viceversa, generando incertezza sul grado di responsabilità applicabile e sulla relativa sanzionabilità.

Tali divergenze si inseriscono in un più ampio contesto di integrazione normativa europea, dove altre discipline – come il Regolamento Generale sulla Protezione dei Dati (GDPR) o il Digital Services Act

(DSA) – introducono ulteriori profili di responsabilità con propri criteri e finalità. Il GDPR, ad esempio, contempla un regime di responsabilità per il trattamento illecito dei dati personali, applicabile anche ove l'evento dannoso derivi da un sistema di IA, ma richiede la dimostrazione di violazione e di nesso causale tra trattamento e danno.³¹ Al contempo, il DSA attribuisce obblighi di diligenza in capo ai prestatori di servizi digitali, con potenziali ricadute sulla responsabilità in caso di diffusione di contenuti illeciti o dannosi.³²

La mancanza di una disciplina unitaria e coerente sulla responsabilità civile da sistemi di Intelligenza Artificiale, evidenziata anche dalla recente discussione europea sulla proposta di direttiva specifica (AI Liability Directive³³) poi ritirata nel 2025, in assenza di un accordo prevedibile tra le istituzioni europee, anche in risposta alle pressioni industriali per un alleggerimen-

to del quadro regolatorio,³⁴ accentua il problema delle zone grigie: il rischio invisibile dell'IA non coincide con elementi facilmente inquadrabili nel diritto comune della responsabilità, richiedendo spesso interpretazioni estensive o dinamico-evolutive di norme preesistenti.

In sintesi, l'interazione tra AI Act e NIS2 mette in luce un sistema normativo articolato e innovativo sul piano della prevenzione e della gestione proattiva del rischio, ma ancora incerto sul piano della determinazione della responsabilità materiale in caso di danno, soprattutto là dove le tecnologie manifestano comportamenti autonomi e complessi. Questo fenomeno rende evidente la necessità di sviluppare ulteriori criteri interpretativi e strumenti giuridici per colmare le lacune e per rendere effettivamente individuabili i soggetti responsabili nel contesto digitale europeo contemporaneo.

³¹ Cfr. art. 82 del Regolamento (UE) 2016/679 (GDPR).

³² Nel Regolamento (UE) 2022/2065 (DSA), la responsabilità dei prestatori di servizi digitali è disciplinata principalmente attraverso un sistema di esenzioni condizionate (artt. 4–6). I fornitori di servizi di mera trasmissione, caching o hosting non sono responsabili per i contenuti illeciti trasmessi o memorizzati, purché non svolgano un ruolo attivo e intervengano tempestivamente una volta acquisita conoscenza dell'illiceità. Il DSA non introduce un autonomo regime generale di responsabilità civile, ma lascia impregiudicate le norme nazionali sul risarcimento del danno. In presenza di sistemi di IA integrati nelle piattaforme, la qualificazione del ruolo del prestatore (neutro o attivo) diventa quindi centrale ai fini dell'eventuale imputazione della responsabilità.

³³ Commissione Europea. *Proposta di direttiva del Parlamento europeo e del Consiglio relativa all'adeguamento delle norme in materia di responsabilità civile extracontrattuale all'intelligenza artificiale (direttiva sulla responsabilità da intelligenza artificiale)*. COM(2022) 496 final. 28 settembre 2022. Consultabile al sito: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX%3A52022PC0496>.

³⁴ L'UE abbandona la direttiva sulla responsabilità dell'IA, 2025, consultabile al sito: <https://www.toplegallacademy.it>.



La Direttiva (UE) 2024/2853 sulla responsabilità per danno da prodotti difettosi: il nuovo tassello del quadro europeo.

Le difficoltà ricostruttive emerse nei paragrafi precedenti, e in particolare l'assenza di una disciplina europea specifica sulla responsabilità civile per danni da Intelligenza Artificiale, hanno trovato una risposta parziale ma significativa nella Direttiva (UE) 2024/2853 del Parlamento europeo e del Consiglio, del 23 ottobre 2024, sulla responsabilità per danno da prodotti difettosi.³⁵ Il provvedimento, pubblicato nella Gazzetta Ufficiale dell'Unione europea il 18 novembre 2024, abroga la storica Direttiva 85/374/CEE, ormai inadeguata al contesto tecnologico contemporaneo, e dovrà essere recepito dagli Stati membri entro il 9 dicembre 2026. Le nuove regole troveranno applicazione

ai prodotti immessi sul mercato successivamente a tale data.

La nuova Product Liability Directive (PLD) si colloca all'interno del pacchetto europeo di interventi sull'innovazione digitale e svolge, rispetto all'AI Act, una funzione complementare. Mentre il Regolamento (UE) 2024/1689 opera *ex ante*, attraverso obblighi di prevenzione, gestione del rischio e compliance, la PLD interviene *ex post*, sul piano risarcitorio, configurando un regime di responsabilità oggettiva del fabbricante per i danni causati da prodotti difettosi. La complementarità ha assunto particolare rilievo dopo il ritiro della proposta di AI Liability Directive, nel febbraio 2025: la PLD costituisce oggi il principa-

³⁵ Direttiva (UE) 2024/2853, consultabile al sito: <https://eur-lex.europa.eu/legal-content/IT/ALL/?uri=CELEX:32024L2853>

le strumento europeo armonizzato in materia di responsabilità civile per danni derivanti da sistemi di IA.

L'innovazione più rilevante riguarda l'ambito di applicazione. L'art. 4, n. 1, ridefinisce la nozione di «prodotto» includendovi espressamente il *software*, i file per la fabbricazione digitale e, di riflesso, i sistemi di Intelligenza Artificiale.

Il considerando 13 chiarisce che il *software* è coperto a prescindere dalle modalità di fornitura: tanto le soluzioni preinstallate quanto i servizi *cloud* erogati in modalità SaaS rientrano nel perimetro della Direttiva. Restano esclusi soltanto i programmi liberi e *open source* sviluppati e forniti al di fuori di un'attività commerciale (art. 2, par. 2). Si tratta di un mutamento di paradigma: l'IA, in quanto risultato di un processo di sviluppo *software*, è oggi un «prodotto» a tutti gli effetti, anche quando viene erogata come servizio.

Sul piano dei soggetti responsabili, la Direttiva delinea una catena articolata che comprende il fabbricante del prodotto e dei suoi componenti, l'importatore, il rappresentante autorizzato, il prestatore di servizi di logistica e, in via residuale, il distributore. Particolare rilievo assume la figura del soggetto che apporta una «modifica sostanziale» a

un prodotto già immesso sul mercato (art. 8): tale operatore assume, limitatamente alla parte modificata, gli obblighi del fabbricante. La previsione si presta a un'applicazione diretta ai modelli di IA per finalità generali successivamente specializzati o riaddestrati da soggetti diversi dal *provider* originario, riproponendo sul versante risarcitorio una logica analoga a quella dell'art. 25 dell'AI Act in tema di traslazione degli obblighi.

La nozione di «difetto», disciplinata dall'art. 7, è anch'essa calibrata sulle tecnologie digitali. Tra gli elementi rilevanti per la sua valutazione la norma menziona la sicurezza che ci si può legittimamente attendere, l'utilizzo prevedibile del prodotto, le aspettative degli utenti, gli effetti dell'autoapprendimento successivo all'immissione sul mercato, il mancato aggiornamento *software* e gli obblighi di *cybersecurity* applicabili. I criteri intercettano in modo diretto le specificità dei sistemi di IA e includono nel perimetro del difetto sia il malfunzionamento *cyber*, in coerenza con la NIS2, sia il comportamento evolutivo del modello successivo al rilascio.

Sul piano processuale, gli artt. 10 e 11 alleggeriscono in modo significativo l'onere della prova in favore del danneggiato.

giato. La Direttiva impone agli operatori economici di esibire le prove tecniche pertinenti in loro possesso (*disclosure*), nel rispetto della tutela del segreto commerciale, e codifica presunzioni di difettosità e di nesso causale che operano, fra l'altro, quando la complessità tecnica o scientifica del prodotto rende eccessivamente difficile la prova diretta. La soluzione affronta in modo specifico il problema del *black box* dei sistemi di IA, restituendo effettività al diritto al risarcimento in contesti caratterizzati da forte asimmetria informativa. Sono inoltre estesi i danni risarcibili, fino a comprendere il danno psicologico medicalmente accertato e la distruzione o corruzione di dati per scopi non professionali (art. 6).

I termini di prescrizione, infine, sono fissati in tre anni dalla conoscenza del danno, con un termine di decadenza di dieci anni dall'immissione sul mercato, prorogabile a venticinque anni per i danni latenti alla persona (art. 16-17).

L'impatto della PLD si proietta direttamente sulla disciplina contrattuale dei sistemi di IA. L'art. 19 vieta di limitare o escludere convenzionalmente la responsabilità del fabbricante nei confronti del danneggiato, qualificando come nulle le clausole contrarie. Le

diffuse pattuizioni di esclusione di garanzia («*as is*»), di limitazione quantitativa del risarcimento e di traslazione integrale del rischio sull'utente, comuni nei contratti analizzati nel capitolo successivo, non potranno dunque operare come schermo rispetto alle azioni risarcitorie fondate sulla nuova Direttiva, almeno nei rapporti con il consumatore.

Si delinea così un sistema in cui la regolazione contrattuale del rischio mantiene piena rilevanza nei rapporti *business-to-business*, ma incontra un limite invalicabile, di matrice pubblicistica, nella tutela del danneggiato finale.

L'introduzione della PLD non risolve integralmente le zone grigie evidenziate in precedenza. Permangono difficoltà nell'individuazione del soggetto responsabile lungo filiere complesse, nella prova del difetto in presenza di *output* probabilistici e nel coordinamento con le discipline civilistiche nazionali. Il nuovo regime offre, tuttavia, uno strumento risarcitorio espressamente calibrato sulle peculiarità dei prodotti digitali e dei sistemi di IA, completando il quadro tracciato dall'AI Act e dalla NIS2 e ricomponendo, almeno in parte, la frattura tra prevenzione del rischio e tutela risarcitoria.

CAPITOLO 2

I SERVIZI DI INTELLIGENZA
ARTIFICIALE NEI MODELLI
CONTRATTUALI ESISTENTI.



I modelli di IA come servizi digitali

Alla luce del quadro normativo europeo delineato, emerge un assetto regolatorio fortemente orientato alla prevenzione del rischio, alla *governance* organizzativa e alla distribuzione ex ante di obblighi tra i diversi attori della filiera dell'Intelligenza Artificiale.

Tuttavia, come evidenziato, tale impianto lascia aperti significativi profili critici.

L'enfasi posta dal Legislatore europeo sugli obblighi di conformità, gestione del rischio e sicurezza informatica non si traduce automaticamente in un sistema altrettanto definito sul piano pratico-sostanziale, dove il contratto si rivela strumento decisivo.

In questo contesto risulta doveroso analizzare come i modelli di IA vengono inquadrati, nella prassi, all'interno di schemi contrattuali preesistenti, in particolare quali servizi digitali.

I modelli di IA generativa, infatti, non sono immessi sul mercato come beni in senso tradizionale, né trasferiti all'utente mediante un contratto di vendita o di cessione definitiva.

Essi vengono, piuttosto, messi a disposizione attraverso schemi contrattuali di tipo licenziatario o di erogazione di servizi, che attribuiscono all'utilizzatore un diritto d'uso delimitato nel tempo e nelle modalità, senza alcun trasferimento della titolarità del sistema o del modello sottostante.

Muovendo da questa premessa, diviene necessario esaminare con particolare attenzione i contratti più frequentemente proposti dai fornitori.

Tali contratti – spesso predisposti unilateralmente da operatori esteri – presentano non di rado profili critici comuni, a partire dalla loro struttura standardizzata e dalla sostanziale impossibilità di negoziare le clausole, con evidenti riflessi in termini di allocazione dei rischi, responsabilità, trattamento dei dati e proprietà intellettuale.

Secondo il paradigma dell'*AI-as-a-Service*, infatti, quale specifica declinazione dei servizi digitali erogati in modalità cloud, l'utente non acquista il modello, ma accede a una funzionalità resa disponibile tramite infrastrutture tecniche e ambienti informatici che restano integralmente nella disponibilità del fornitore.

È il caso, ad esempio, dei servizi offerti da OpenAI attraverso ChatGPT, da Microsoft con Microsoft

Copilot e da Google mediante Google Gemini.

A tal proposito, il *Software as a Service* (SaaS) costituisce un modello di erogazione del software fondato sull'accesso remoto, nel quale il cliente non riceve una copia del programma da installare – come invece avviene per il modello tradizionale on-premise – sui propri dispositivi, ma utilizza un'applicazione resa disponibile via internet e ospitata sul server del fornitore, che gestisce infrastruttura, manutenzione, aggiornamenti, sicurezza e continuità operativa.

Sul piano giuridico, tale configurazione comporta che il cliente acquisisce un diritto di utilizzo limitato nel tempo e nelle modalità, subordinato al rispetto di specifiche clausole contrattuali e, di regola, al pagamento di un canone periodico.

Ne deriva che il contratto SaaS deve disciplinare con particolare attenzione i livelli di servizio (SLA), ³⁶ specificando parametri quali *uptime*, tempi di intervento,

³⁶ *Service Level Agreement*, clausole rafforzate in materia di sicurezza o specifiche disposizioni sulla protezione dei dati.

continuità del servizio e rimedi in caso di interruzioni o modifiche delle funzionalità.³⁷

Solo attraverso una regolamentazione puntuale di tali aspetti è possibile garantire un adeguato equilibrio tra le esigenze operative del cliente e la struttura tecnico-organizzativa del fornitore, che rimane il vero *dominus* dell'infrastruttura digitale.

In alternativa a queste soluzioni, si può optare per lo sviluppo di un sistema personalizzato, costruito su uno specifico modello di Intelligenza Artificiale e alimentato da *dataset* selezionati in funzione delle esigenze del committente. Si tratta di una soluzione “su misura”, pensata per rispondere a funzionalità e obiettivi specifici.

Tale soluzione negoziale, tuttavia, implica generalmente maggiori costi e complessità, dunque risulta meno utilizzata. Essa richiede attività preliminari di individuazione e validazione dei *dataset*, un'accurata progettazione di processi e funzio-

nalità e, soprattutto, una puntuale disciplina contrattuale dell'accesso alle informazioni tecniche relative allo sviluppo, inclusi codice sorgente e algoritmi. Solo attraverso una regolamentazione chiara di questi aspetti il committente può assicurarsi un controllo effettivo sul sistema e la possibilità di gestirlo autonomamente, anche con il supporto di sviluppatori terzi.³⁸

³⁷ Contratti SaaS: guida legale a SLA, dati e aggiornamenti (2025), consultabile al sito: <https://www.avvocatitech.com>.

³⁸ Lavagnini S., Contratti AI in azienda: clausole essenziali e rischi legali, in [agendadigitale.eu](https://www.agendadigitale.eu), 2025.



Analisi dei principali servizi di IA nel contesto attuale: ChatGPT (OpenAI)

Il contratto predisposto da OpenAI per l'utilizzo di ChatGPT si inserisce pienamente nello schema tipico di fornitura di servizi digitali in modalità *Software as a Service*, presentando naturalmente le peculiarità strettamente connesse alla natura dei sistemi di Intelligenza Artificiale generativa.

L'utente, infatti, non acquisisce alcun diritto di proprietà sul *software* né sui modelli di Intelligenza Artificiale, ma ottiene un diritto di accesso e utilizzo non esclusivo, temporalmente limitato alla durata dell'abbonamento o del piano attivo e revocabile in

caso di violazione delle condizioni contrattuali.

La struttura documentale del rapporto è articolata e stratificata. Richiedono maggiore attenzione, in via generale, i Termini di utilizzo (*Terms of Service*),³⁹ eventuali condizioni specifiche per i piani a pagamento (quali *Plus*, *Team* o *Enterprise*),⁴⁰ la *Privacy Policy*⁴¹ e, per i clienti *business*, un *Data Processing Addendum* (DPA).⁴²

L'oggetto del contratto consiste nell'accesso a una piattaforma di Intelligenza Artificiale generativa che consente l'interazione tramite *prompt*

³⁹ <https://openai.com/it-IT/policies/terms-of-use>.

⁴⁰ <https://openai.com/it-IT/policies/services-agreement>.

⁴¹ <https://openai.com/it-IT/policies/privacy-policy>.

⁴² <https://openai.com/it-IT/policies/data-processing-addendum>.

testuali e, a seconda del piano, anche vocali o multimodali, nonché la generazione di *output* quali testi, codice o altri contenuti.

Per sviluppatori e imprese è inoltre disponibile l'integrazione tramite API,⁴³ che permettono di incorporare le funzionalità del modello all'interno di applicazioni o sistemi terzi. Il fornitore mantiene in ogni caso il pieno controllo sull'infrastruttura tecnica, sui modelli e sugli aggiornamenti, riservandosi espressamente la facoltà di modificare, aggiornare o interrompere il servizio.

Uno degli aspetti centrali del regolamento contrattuale riguarda la disciplina dei contenuti, distinti in *input* e *output*.

L'utente conserva, in linea generale, la proprietà dei contenuti immessi nel sistema (cioè gli *input*). Per quanto concerne l'*output* generato, tutti i diritti su di esso vengono attribuiti all'utente – nei limiti consentiti dalla legge e dalle condizioni contrattuali – con esclusione di garanzie circa l'ori-

ginalità assoluta dei risultati. Nei piani destinati ai consumatori (B2C) è normalmente prevista la possibilità che i contenuti siano utilizzati per il miglioramento dei modelli (cd. *training data*), salvo eventuale *opt-out*; nei piani *enterprise*, invece, tale utilizzo è generalmente escluso.

Il contratto contiene inoltre una serie di limitazioni d'uso. È vietato impiegare il servizio per finalità illecite o in violazione della normativa applicabile, tentare attività di *reverse engineering* o di estrazione del modello, utilizzare l'*output* per sviluppare sistemi concorrenti o impiegare lo strumento in ambiti ad alto rischio senza adeguata supervisione umana. La violazione di tali clausole può comportare la sospensione o la cessazione dell'*account*.

Nel quadro delineato dai Termini di Utilizzo di OpenAI, il regime di responsabilità si inserisce pienamente nella tradizione dei contratti di servizi digitali e, in particolare, dei modelli SaaS. La struttura complessiva evidenzia una chiara allocazione del rischio con-

⁴³ Le API di ChatGPT (Application Programming Interface) sono ponti *software* forniti da OpenAI che permettono agli sviluppatori e alle aziende di integrare le capacità di Intelligenza Artificiale di ChatGPT (come GPT-4, GPT-3.5, o modelli più recenti come il 4.1-mini) direttamente all'interno delle proprie applicazioni, siti web, o *software*; maggiori informazioni al sito: <https://www.datacamp.com/tutorial/a-beginners-guide-to-chatgpt-api>.

trattuale a favore del fornitore, attraverso una combinazione di esclusioni di garanzia, limitazioni quantitative della responsabilità e clausole di manleva.

Anzitutto, il servizio viene fornito secondo la formula “*as is*” e “*as available*”. Ciò significa che OpenAI non presta garanzie espresse o implicite circa l'accuratezza, l'affidabilità, la continuità o l'idoneità del servizio a uno scopo specifico. In termini sostanziali, il fornitore qualifica il sistema di Intelligenza Artificiale come uno strumento tecnologico sperimentale o comunque non infallibile, il cui *output* deve essere verificato dall'utente prima di essere utilizzato per decisioni rilevanti. Questa impostazione è coerente con la natura probabilistica dei modelli generativi, ma produce un effetto giuridico significativo: l'affidamento *sull'output* non è contrattualmente garantito.

A tale esclusione di garanzie si affianca una limitazione quantitativa della responsabilità. I Termini prevedono normalmente un tetto massimo risarcitorio, parametrato agli importi corrisposti dall'utente in un determinato periodo (ad esempio, gli ultimi dodici mesi), oppure a una soglia minima

prestabilita. In questo modo, anche nell'ipotesi in cui venga accertata una responsabilità contrattuale del fornitore, l'esposizione economica risulta predeterminata, contenuta e limitata.

Si tratta di una clausola tipica dei contratti *cloud*, che mira a rendere prevedibile il rischio economico dell'operatore, ma che, in ambito europeo, potrebbe non essere esente dal sollevare perplessità alla luce della disciplina sulle clausole vessatorie nei contratti con i consumatori.

Un ulteriore elemento caratterizzante è l'esclusione dei danni indiretti o consequenziali. Vengono generalmente esclusi il lucro cessante, la perdita di opportunità commerciali, la perdita di dati, i danni reputazionali e, più in generale, i danni non direttamente imputabili alla prestazione principale. Ciò riduce drasticamente la possibilità di ottenere un risarcimento integrale nel caso in cui un *output* errato produca effetti economici significativi a catena.

In questa prospettiva, il contratto in esame sembra configurare l'obbligazione del fornitore come un'obbligazione di mezzi tecnologici, e non come un'obbligazione di risultato informativo.

Particolarmente rilevante è poi la disciplina dell'uso *dell'output*. I Termini sottolineano che l'utente è responsabile delle decisioni assunte sulla base dei contenuti generati e che deve valutarne l'accuratezza e l'appropriatezza rispetto allo scopo perseguito. Questa previsione opera come una vera e propria traslazione del rischio: il sistema viene presentato come strumento di supporto e non come consulente qualificato.

Ne deriva che l'eventuale errore *dell'output*, salvo malfunzionamenti imputabili al fornitore, ricade in larga misura nella sfera di responsabilità dell'utilizzatore.

Il contratto prevede inoltre clausole di manleva (*indemnification*) a carico dell'utente, il quale si impegna a tenere indenne il fornitore da pretese di terzi derivanti dall'uso illecito del servizio o dalla violazione dei termini contrattuali. Nei contratti business, tuttavia, la disciplina può essere più articolata e talvolta includere forme di tutela in favore del cliente, ad esempio in caso di violazione di diritti di proprietà intellettuale, entro limiti e condizioni specifiche.

La situazione muta, almeno in parte, nei piani *enterprise* o nei contratti

negoziati individualmente. In tali casi possono essere previsti SLA, con garanzie di *uptime* e rimedi contrattuali in caso di disservizio (quali *service credits*), nonché limiti di responsabilità più elevati o diversamente modulati. La disciplina della sicurezza, della protezione dei dati e delle misure tecniche può risultare più dettagliata, e il tetto massimo di responsabilità può essere oggetto di negoziazione. Ciò conferma che il regime di responsabilità non è uniforme, ma varia in funzione del potere contrattuale della controparte.

Per ciò che riguarda la protezione dei dati personali, per i clienti aziendali il trattamento è disciplinato mediante un *Data Processing Addendum* che regola le misure tecniche e organizzative di sicurezza e, ove necessario, i trasferimenti internazionali di dati. In tale assetto, il cliente *business* assume il ruolo di titolare del trattamento rispetto ai dati inseriti, mentre il fornitore opera quale responsabile.

Il contratto prevede infine la possibilità di recesso da parte dell'utente, generalmente con cessazione del rinnovo automatico, nonché la facoltà del fornitore di sospendere o interrompere il servizio e di modificare unila-

teralmente le condizioni contrattuali previa comunicazione. Tale configurazione rafforza la natura di contratto per adesione, con condizioni predisposte unilateralmente dal *provider* e margini di negoziazione limitati, con qualche eccezione per i clienti *enterprise*.

2.2.1

COPILOT (MICROSOFT)

I servizi di IA generativa di Microsoft si inseriscono in un ecosistema ancor più articolato e stratificato, che combina modelli linguistici avanzati, strumenti di sviluppo e un'integrazione profonda con le piattaforme Microsoft 365 e Azure.

Al centro di questo sistema si colloca la famiglia Microsoft Copilot, che rappresenta l'interfaccia più immediata dell'IA generativa per utenti privati, professionisti e imprese. Copilot non è un prodotto unico, ma un insieme di soluzioni: dalla versione gratuita integrata in Windows, Edge e Bing, alla versione Pro per utenti *consumer*, fino a Copilot for Microsoft 365, integrato nei programmi Word, Excel,

PowerPoint, Outlook e Teams, oltre a GitHub Copilot per la generazione di codice e Copilot Studio per la creazione di agenti personalizzati.

In tutte queste declinazioni, l'elemento comune è la generazione di testi, immagini, codice e analisi, con interazione multimodale e un forte collegamento ai dati dell'utente, soprattutto in ambito aziendale.

Dal punto di vista tecnologico e contrattuale, l'architettura di Copilot si fonda sulla *partnership* tra Microsoft e OpenAI. I modelli (come GPT-4 e successive evoluzioni) sono sviluppati da OpenAI, ma vengono concessi in licenza a Microsoft, che li distribuisce tramite la propria infrastruttura cloud Azure e li integra nei propri prodotti. Quando un utente utilizza Copilot in Word o Excel, il prompt viene inviato ai server Microsoft, che determina quale modello impiegare per l'elaborazione dei dati e la generazione dell'output, attività che, seppur svolta da modelli sviluppati da un soggetto terzo (OpenAI), avviene in ogni caso in un ambiente cloud controllato dallo stesso Microsoft; l'output viene poi restituito e presentato all'utente.

I dati non vengono trasmessi a OpenAI: ne deriva una netta separazione

dei ruoli nella filiera: OpenAI sviluppa il modello, ma non ha un rapporto contrattuale diretto con l'utente finale; Microsoft lo integra, lo distribuisce e risponde contrattualmente nei confronti dell'utente. Questo assetto incide profondamente sulla struttura delle responsabilità, che in ogni caso incide soltanto sull'utente e su Microsoft.

Per utilizzare un servizio di IA di Microsoft, l'utente deve accettare un sistema contrattuale articolato. Nei servizi *consumer* (come Microsoft Copilot) si applica principalmente il *Microsoft Services Agreement*,⁴⁴ insieme all'informativa privacy:⁴⁵ l'utente ottiene una licenza d'uso non esclusiva, accetta limitazioni di responsabilità e si assume il rischio legato all'uso dell'*output* generato dall'IA.

Nei servizi *enterprise* (es. Microsoft 365 Copilot o Azure OpenAI Service) il quadro è più complesso: oltre al contratto principale (*Customer/Enterprise Agreement*), si applicano i *Product Terms*⁴⁶ e il *Data Protection Adden-*

dum,⁴⁷ che disciplinano sicurezza, trattamento dei dati e allocazione del rischio.

Nel caso di Copilot, rispetto a ChatGPT, la posizione contrattuale di Microsoft appare più articolata e, per certi versi, più esplicita. Oltre a ribadire che l'*output* non è garantito come corretto o idoneo a uno specifico scopo, Microsoft sottolinea in modo molto più marcato che l'utente rimane pienamente responsabile delle decisioni adottate sulla base dei contenuti generati dall'IA. L'*output* è qualificato come mero supporto o suggerimento, che richiede supervisione umana e controllo professionale, specialmente in ambiti sensibili (giuridico, finanziario, sanitario).

Nei piani *enterprise*, inoltre, Microsoft accompagna questa allocazione del rischio con strumenti di *governance* – come sistemi di *audit*, *logging*, controllo degli accessi e misure di sicurezza avanzate – che consentono alle organizzazioni di monitorare e gestire l'uso dell'IA in modo strutturato. Mi-

⁴⁴ <https://www.microsoft.com/it-it/servicesagreement>.

⁴⁵ <https://www.microsoft.com/it-it/privacy/privacystatement>.

⁴⁶ <https://www.microsoft.com/licensing/terms>.

⁴⁷ <https://www.microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA>.

Microsoft dedica particolare attenzione, nei propri Termini e nelle comunicazioni agli utenti, ad evidenziare la possibilità che gli *output* generati, in particolare da GitHub Copilot, possano essere coperti da diritti di proprietà intellettuale. Ciò è legato al fatto che il sistema è stato addestrato anche su ampie quantità di codice pubblicamente disponibile, inclusi numerosi archivi *open-source*. Di conseguenza, Microsoft è particolarmente attento nel non fornire alcuna garanzia di originalità dell'*output* e nel non assicurare che il codice suggerito sia privo di somiglianze sostanziali con opere preesistenti.

Questo profilo rappresenta un nodo giuridicamente sensibile: qualora il codice generato dovesse coincidere, in tutto o in parte, con *software* distribuito sotto licenze *open-source* di tipo *copyleft*⁴⁸ potrebbero sorgere specifici obblighi giuridici per l'utilizzatore. In tali casi, l'integrazione del frammento nel proprio progetto potrebbe comportare l'applicazione delle condizioni previste dalla licenza originaria, con possibili implicazioni sulla

distribuzione e sulla scelta del regime giuridico del *software* finale.

Per ciò che riguarda l'uso dei dati per finalità di *training*, nei servizi *consumer* è subordinato al consenso, a differenza di quanto previsto per ChatGPT che, come visto, ne prevede l'impiego di *default* salvo *opt-out*; nei contesti *enterprise*, i dati dei clienti, invece, non vengono mai utilizzati per addestrare i modelli.

Sotto il profilo della gestione del rischio, emergono quindi due modelli di contrattualizzazione dell'IA generativa.

Con ChatGPT il rischio è in larga misura trasferito all'utente finale con minori garanzie contrattuali standard e un controllo dei dati che, nei piani *consumer*, può risultare meno strutturato. Con Copilot, invece, il rischio appare più "ingegnerizzato" e inserito in un ecosistema regolato: il rischio non è semplicemente "scaricato" sull'utente, ma incanalato in una struttura regolata e modulabile; la gestione del rischio non è solo giuridica, ma anche

⁴⁸ Le licenze *copyleft* – come la GNU General Public License (GPL) – consentono l'uso, la modifica e la distribuzione del codice, ma impongono una condizione fondamentale: qualsiasi opera derivata deve essere distribuita a sua volta sotto la stessa licenza. Ciò significa, ad esempio, che se un frammento di codice GPL viene incorporato in un *software* proprietario e distribuito, l'intero *software* potrebbe dover essere rilasciato sotto GPL, con obbligo di rendere disponibile il codice sorgente.

tecnicamente incorporata nell'infrastruttura *cloud* (segregazione dei dati, controlli, sicurezza).

Il rischio risulta progettato e gestito attraverso misure tecniche e organizzative codificate contrattualmente; l'integrazione con Microsoft 365 e Azure consente poi un maggiore controllo tecnico-organizzativo, una diversa ripartizione dei ruoli nella filiera (sviluppatore del modello vs distributore integratore) e, nei contratti *enterprise*, una negoziabilità più ampia delle clausole di responsabilità, in particolare per ciò che riguarda ipotesi di indennizzo in caso di violazione di diritti di terzi. Nel modello ChatGPT, invece, sviluppatore e fornitore coincidono e il contratto standard concentra le clausole di esclusione di responsabilità senza una tale struttura multilivello di *governance* tecnica.

Resta fermo che anche in questo modello l'utente conserva la responsabilità ultima per le decisioni adottate sulla base dell'*output* generato dall'IA; tuttavia, tale responsabilità si colloca in un contesto contrattuale e infra-

strutturale più strutturato, in cui la gestione del rischio appare progettata e integrata nel sistema complessivo del servizio, piuttosto che affidata unicamente a una generica esclusione di garanzie.

2.2.2

GEMINI (GOOGLE)

Anche nel caso di Google, la disciplina contrattuale dei servizi di IA generativa basati su Google Gemini non è contenuta in un unico documento standard facilmente identificabile, ma si articola in una pluralità di fonti che variano in funzione del contesto d'uso (*consumer*, *API*, *Workspace*, *Cloud*).

In particolare, si applicano i Google *Terms of Service* ⁴⁹ – di carattere generale e aggiornati per includere disposizioni sull'IA generativa – cui si affiancano termini specifici per le API (Gemini API *Additional Terms*), ⁵⁰ le Service Specific Terms ⁵¹ di Google Workspace per l'integrazione nelle

⁴⁹ <https://policies.google.com/terms/generative-ai>.

⁵⁰ <https://ai.google.dev/gemini-api/terms>.

⁵¹ <https://workspace.google.com/terms/service-terms>.

applicazioni di produttività e le condizioni di Google Cloud ⁵² (ad esempio per Vertex AI e l'uso *enterprise* dei modelli). Il quadro è completato dal *Data Processing Addendum* ⁵³ in materia di protezione dei dati nei piani a pagamento.

Ne risulta una struttura modulare: più articolata rispetto al contratto relativamente unitario di ChatGPT (*Terms of Use + Privacy Policy*), ma meno stratificata rispetto all'architettura multilivello tipica di Microsoft (*Customer Agreement, Product Terms, DPA*).

Una prima peculiarità del modello Gemini è la distinzione contrattuale esplicita tra servizi gratuiti e servizi a pagamento. Nei "*Paid Services*" Google dichiara di non utilizzare *prompt* e *output* per l'addestramento dei modelli e di trattare i dati secondo le previsioni del DPA; negli "*Unpaid Services*", invece, i contenuti possono essere utilizzati per il miglioramento dei prodotti, anche mediante revisione umana. Tale distinzione risulta formalizzata in modo più netto e chiaro rispetto, ad esempio, al modello già analizzato di OpenAI.

Con riferimento alla proprietà *dell'output*, Google adotta una formulazione relativamente semplice: dichiara di non rivendicare diritti di proprietà sui contenuti generati dall'utente, lasciando a quest'ultimo la possibilità di utilizzarli e pubblicarli, ferma restando la responsabilità per il loro impiego. Questa impostazione si differenzia tecnicamente sia da OpenAI, che utilizza una formula di assegnazione ("*assignment*") dei diritti sull'*output* all'utente, sia da Microsoft, che nei servizi *enterprise* qualifica l'*output* come parte dei "*Customer Data*".

Google, dunque, non struttura una vera e propria cessione formale dei diritti, ma si limita a escludere una propria pretesa proprietaria.

Particolarmente rilevante è la previsione, nei contratti *Google Cloud* e *Workspace*, di una clausola specifica di indennizzo per l'*output* generato: in ambito *enterprise*, Google può impegnarsi a tenere indenne il cliente da rivendicazioni di terzi per violazione di diritti di proprietà intellettuale derivanti *dall'output* dell'IA, entro li-

⁵² <https://cloud.google.com/terms/service-terms>.

⁵³ <https://business.safety.google/processorterms>.

miti e soglie massime di responsabilità e con esclusione dei casi di uso improprio, modifica *dell'output* o disattivazione dei filtri di sicurezza. Tale previsione risulta più esplicita, seppur simile, rispetto ai Termini di ChatGPT, mentre nel modello Copilot l'indennizzo è generalmente inserito nel più ampio regime di *IP indemnification*⁵⁴ dei contratti Microsoft enterprise e non sempre configurato come clausola autonoma riferita specificamente al contenuto generato dall'IA.

Quanto alle restrizioni d'uso, anche Gemini prevede divieti specifici quali il reverse engineering, l'estrazione sistematica di dati o l'uso *dell'output* per sviluppare modelli concorrenti, oltre a una *Prohibited Use Policy* integrata nei termini generali Google.

Sotto il profilo dell'affidabilità, infine, anche Google precisa che il servizio è fornito "*as is*", senza garanzie di accuratezza o idoneità a uno scopo particolare, e invita l'utente a non fare affidamento *sull'output* per decisioni professionali (mediche, legali, finan-

ziarie) senza adeguata verifica.

Su questo punto, la posizione di Gemini si allinea sostanzialmente a quella di ChatGPT e Copilot: in tutti e tre i modelli permane una significativa allocazione del rischio decisionale in capo all'utente, pur con minime differenze nella struttura contrattuale e negli strumenti di indennizzo e *governance* previsti in ambito *enterprise*.

⁵⁴ Per *IP indemnification* si intende la clausola – tipica dei contratti *enterprise* Microsoft – con cui l'azienda si impegna a difendere e tenere indenne il cliente da pretese di terzi fondate sulla violazione di diritti di proprietà intellettuale (*copyright*, brevetti, marchi, segreti commerciali) derivante dall'uso dei prodotti o servizi Microsoft conformemente al contratto. Nel caso di Microsoft Copilot, l'eventuale copertura *dell'output* generato rientra normalmente all'interno di questo regime generale di *IP indemnification*, cioè non come clausola autonoma dedicata esclusivamente all'"output AI", ma come applicazione del sistema generale di tutela IP previsto per tutti i servizi Microsoft.



Profili critici di compatibilità con AI Act e NIS2

L'analisi dei contratti di fornitura dei modelli di IA generativa – con riferimento a i principali fornitori succitati – consente di individuare alcuni profili critici di compatibilità con il quadro normativo europeo delineato dal AI Act e dalla NIS2, soprattutto in relazione alla ripartizione delle responsabilità, alla trasparenza e agli obblighi di gestione del rischio.

Un primo nodo riguarda la qualificazione dei ruoli lungo la filiera dell'IA.

L'AI Act, come si è avuto modo di analizzare, distingue tra *provider*, *deployer* e altri operatori economici, attribuendo a ciascuno obblighi differenziati in materia di documentazione tecnica, gestione del

rischio sistemico, trasparenza e sicurezza.

Nei contratti analizzati, tuttavia, la tendenza è quella di concentrare verso l'utente finale – specie nei piani *consumer* – una quota significativa del rischio decisionale e applicativo.

Le clausole che impongono all'utente di verificare *l'output*, di non farvi affidamento per decisioni critiche e di assumersi la responsabilità dell'uso possono entrare in tensione con la *ratio* regolatoria europea, che attribuisce obblighi diretti anche ai *provider* dei modelli, specialmente quando si tratta di modelli di uso generale con potenziale impatto sistemico, al fine di distribuire e razionalizzare

la responsabilità in capo a più soggetti diversi.

Particolarmente delicato, di conseguenza, è il tema dell'indennizzo per violazione di diritti di proprietà intellettuale derivante *dall'output* generato.

L'AI Act, pur non disciplinando direttamente il *copyright*, impone obblighi di trasparenza⁵⁵ con riferimento all'uso di contenuti protetti per l'addestramento dei modelli GPAI.

Questo obbligo di trasparenza mal si concilia con i consueti termini contrattuali di servizi di IA: richiede, infatti, informazioni pubblicamente accessibili sulla composizione dei dati di addestramento, inclusi quelli protetti da *copyright*.

Spesso le informazioni tecniche sui *dataset* di addestramento, sulle metriche di *performance* o sulle misure di mitigazione del rischio sono sintetiche o rinviate a documentazione separata e modificabile unilateralmente.

Si tratta di un livello di trasparenza

che difficilmente risulta soddisfatto dai termini standard di servizio (che spesso limitano l'uso dei dati e non obbligano a rendere pubblici i dettagli dei *dataset*) e che potenzialmente può creare asimmetrie informative rilevanti anche per i clienti *enterprise* che intendano integrare tali modelli in sistemi potenzialmente qualificabili come "ad alto rischio" ai sensi dell'AI Act.

Nei contratti analizzati, poi, la copertura del rischio IP varia sensibilmente: ChatGPT, nei termini standard, non prevede un indennizzo generalizzato; Copilot lo inserisce nel più ampio regime di *IP indemnification enterprise*; Gemini contempla clausole specifiche di indennizzo per *l'output* generato nei contratti *cloud*.

Tuttavia, in tutti i casi tali clausole sono soggette a massimali e a esclusioni rilevanti (uso improprio, modifica *dell'output*, elusione dei filtri), con conseguente permanenza di una quota significativa di rischio in capo all'utente-*deployer*, che potrebbe trovarsi particolarmente esposto anche rispetto agli

⁵⁵ Cfr. art. 53 e cons. 107 del Regolamento (UE) 2024/1689 (AI Act).

obblighi di conformità previsti dal diritto europeo.

Tale previsione negoziale, se da un lato contribuisce a colmare il vuoto normativo in materia di risarcimento del danno, dall'altro finisce per trasferire sull'utilizzatore l'intero peso delle conseguenze derivanti dalla concretizzazione del rischio.

Un ulteriore aspetto riguarda la sicurezza informatica e la conformità alla NIS2. La Direttiva impone obblighi stringenti di gestione del rischio *cyber*, continuità operativa e notifica degli incidenti per i soggetti essenziali e importanti.

Nei contratti *enterprise* di Microsoft e Google si riscontra una maggiore strutturazione delle misure di sicurezza (*audit*, *logging*, segregazione dei dati, SLA, DPA), che può agevolare la *compliance* degli operatori soggetti a NIS2.

Nei servizi *consumer*, invece, la disciplina è più standardizzata e meno negoziabile, con limitazioni significative di responsabilità e assenza di garanzie specifiche in termini di livelli di servizio o resilienza, elementi che potrebbero risultare

insufficienti per operatori rientranti nel perimetro NIS2.

Infine, emerge una possibile tensione tra la clausola "*as is*", comune a tutti e tre i fornitori, e l'approccio *risk-based* dell'AI Act.

Se da un lato i contratti escludono garanzie di accuratezza e affidabilità *dell'output*, dall'altro la normativa europea richiede che i sistemi (specie se ad alto rischio) siano progettati e gestiti in modo da garantire livelli adeguati di sicurezza, robustezza e qualità dei dati.

Ne deriva che l'utente professionale, per essere conforme all'AI Act e alla NIS2, non può limitarsi ad accettare le condizioni standard del fornitore, ma deve valutare attentamente – anche in sede di negoziazione contrattuale – se le garanzie offerte siano sufficienti a coprire i propri obblighi regolatori.

In conclusione, i contratti di fornitura dei modelli di IA generativa mostrano una tendenza comune alla limitazione della responsabilità del *provider* e alla traslazione del rischio sull'utente; tuttavia, l'AI Act e la NIS2 introducono una logica regolatoria che mira a redistribuire

parte di tale rischio a livello sistemico.

Il punto critico, per gli operatori europei, diventa la capacità di riallineare la disciplina contrattuale privata con gli obblighi pubblicistici emergenti, evitando che la mera accettazione di clausole standard si traduca in un'esposizione a responsabilità non coerente con il quadro normativo dell'Unione.

D'altro canto, il persistente squilibrio contrattuale continua a rappresentare un tema rilevante, tanto alla luce della normativa a tutela del consumatore, quanto quale stimolo per l'elaborazione di clausole più equilibrate nella distribuzione delle responsabilità e gestione del rischio tra i diversi soggetti coinvolti nella filiera dell'IA.

CAPITOLO 3

LE LINEE GUIDA AGID E
PROBLEMATICHE DI
RESPONSABILITÀ.



Il ruolo di AgID nella governance dell'IA

Nel sistema italiano di *governance* della trasformazione digitale della Pubblica Amministrazione, un ruolo centrale è attribuito all'Agenzia per l'Italia Digitale (AgID), cui il Legislatore ha affidato funzioni di indirizzo strategico, coordinamento tecnico e supporto operativo nell'attuazione delle politiche di digitalizzazione.

Il fondamento normativo di tali competenze è rinvenibile nel Codice dell'Amministrazione Digitale (D.Lgs. 82/2005), che attribuisce all'Agenzia il compito di promuovere l'innovazione

tecnologica nella Pubblica Amministrazione e di garantire l'omogeneità dei processi di digitalizzazione attraverso l'adozione di standard tecnici, linee guida e raccomandazioni rivolte alle amministrazioni pubbliche.⁵⁶

In particolare, ai sensi dell'art. 71 del CAD, l'AgID è competente ad adottare linee guida volte a definire regole tecniche e operative per l'attuazione delle disposizioni in materia di amministrazione digitale, strumenti che assumono una funzione di indirizzo e coordinamento nell'ambito dell'azione amministrativa.

⁵⁶ Cfr. art. 14-bis D.Lgs. 82/2005 (CAD): "L'Agenzia per l'Italia Digitale (AgID) è preposta alla realizzazione degli obiettivi dell'Agenda Digitale Italiana, in coerenza con gli indirizzi dettati dal Presidente del Consiglio dei ministri o dal Ministro delegato, e con l'Agenda digitale europea. AgID, in particolare, promuove l'innovazione digitale nel Paese e l'utilizzo delle tecnologie digitali nell'organizzazione della pubblica amministrazione e nel rapporto tra questa, i cittadini e le imprese, nel rispetto dei principi di legalità, imparzialità e trasparenza e secondo criteri di efficienza, economicità ed efficacia. Essa presta la propria collaborazione alle istituzioni dell'Unione europea e svolge i compiti necessari per l'adempimento degli obblighi internazionali assunti dallo Stato nelle materie di competenza." (co.1).

L'azione di AgID si colloca in una dimensione di regolazione prevalentemente tecnico-organizzativa, volta a fornire alle Amministrazioni indicazioni operative per un utilizzo responsabile e consapevole delle tecnologie di IA: l'Agenzia mira a orientare l'adozione di sistemi di Intelligenza Artificiale nella Pubblica Amministrazione secondo principi di sicurezza, qualità dei dati, tracciabilità delle decisioni algoritmiche e controllo umano sui processi automatizzati.

La funzione svolta da AgID può essere ricondotta a un modello di *soft regulation*, nel quale l'intervento regolatorio non assume la forma di norme primarie o secondarie, ma si realizza attraverso strumenti di indirizzo tecnico-amministrativo. Tali strumenti assumono particolare rilevanza in ambiti tecnologici caratterizzati da rapida evoluzione, come appunto quello dell'IA, nei quali il ricorso a regole tecniche flessibili consente di accompagnare l'innovazione senza irrigidire eccessivamente il quadro normativo.

Il ruolo di AgID deve inoltre essere letto nel quadro della più ampia *governance* multilivello dell'Intelligenza Artificiale, che vede l'interazione tra fonti e attori a livello europeo e nazionale.

In particolare, le iniziative dell'Agenzia si inseriscono nel contesto delle politiche europee in materia di regolazione dell'IA, nonché nel più ampio sistema di norme relative alla sicurezza informatica e alla gestione del rischio digitale. In questo quadro, AgID svolge una funzione di raccordo tra il livello sovranazionale e quello nazionale, contribuendo alla traduzione operativa dei principi normativi europei in indicazioni applicative rivolte alle Amministrazioni Pubbliche italiane.



La contrattualizzazione della responsabilità come risposta funzionale

Le Linee Guida per l'adozione di sistemi di Intelligenza Artificiale nella Pubblica Amministrazione elaborate dall'AgID rappresentano uno dei principali strumenti tecnico-organizzativi in materia, destinati a orientare le Amministrazioni nell'impiego di tecnologie algoritmiche.

Il documento dedicato all'adozione dei sistemi di IA nella PA ha attraversato una fase di consultazione pubblica, ed è ora in attesa di pubblicazione del

testo in via definitiva; la consultazione è stata avviata il 18 febbraio 2025 con Determinazione n. 17/2025⁵⁷ ed è terminata il 20 marzo 2025, consentendo a istituzioni, operatori e cittadini di presentare osservazioni e proposte.⁵⁸

Le Linee Guida si inseriscono inoltre nel più ampio contesto strategico delineato dal Piano Triennale per l'informatica nella Pubblica Amministrazione 2024-2026,⁵⁹ adottato con D.P.C.M. 12 gennaio 2024, e trovano ulteriore

⁵⁷ <https://trasparenza.agid.gov.it/page/103/details/5299/determinazione-n-17-del-17-febbraio-2025-avvio-delliter-di-consultazione-e-informazione-delle-linee-guida-per-ladozione-dellintelligenza-artificiale-nella-pubblica-amministrazione.html>.

⁵⁸ La funzione di indirizzo e supporto svolta da AgID è esercitata in maniera permanente e continuativa: dal 12 marzo 2026 all'11 aprile 2026 sono state sottoposte a consultazione pubblica anche le "Linee Guida per lo sviluppo di sistemi di Intelligenza Artificiale nella Pubblica Amministrazione" e le "Linee Guida per il procurement di IA nella Pubblica Amministrazione", adottate con la Determinazione n. 43/2026 (consultabile al sito: <https://trasparenza.agid.gov.it/page/103/details/5557/determinazione-del-direttore-generale-n-43-del-10-marzo-2026-avvio-delliter-di-consultazione-e-informazione-delle-linee-guida-per-lo-sviluppo-e-il-procurement-dellintelligenza-artificiale-nella-pubblica-amministrazione.html>).

⁵⁹ <https://www.agid.gov.it/it/agenzia/piano-triennale>.

fondamento nell'art. 2 del CAD, che definisce l'ambito soggettivo di applicazione della disciplina dell'amministrazione digitale.

Il documento si rivolge infatti a tutti i soggetti indicati al comma 2 di tale articolo – Amministrazioni centrali, Enti territoriali e altri Organismi pubblici – e si occupa delle modalità di progettazione, acquisizione e utilizzo dei sistemi di Intelligenza Artificiale all'interno delle loro attività istituzionali.

Dal punto di vista strutturale, le Linee Guida sono corredate da nove allegati tecnici, qualificati come "strumenti", progettati per essere aggiornati con maggiore rapidità rispetto al testo principale, in modo da consentire un adeguamento continuo all'evoluzione tecnologica e normativa.

Uno degli elementi centrali del documento è rappresentato dall'approccio alla gestione del rischio connesso all'impiego dell'Intelligenza Artificiale nei processi amministrativi. In tale prospettiva, le Linee Guida non si limitano a promuovere l'innovazione tecnologica, ma definiscono un quadro metodologico volto a garantire che l'adozione dei sistemi di IA avvenga in modo controllato e conforme ai principi dell'azione amministrativa.

A partire dal capitolo 3 del documento si sviluppano, infatti, un insieme di principi fondamentali con lo scopo di guidare le Pubbliche Amministrazioni nell'adozione, nell'acquisto e nello sviluppo di sistemi di IA, e di assicurare che tali tecnologie siano impiegate in modo etico, responsabile e conforme alle normative vigenti, massimizzando al contempo i benefici per i cittadini e per l'efficienza amministrativa. In particolare, le Amministrazioni sono invitate ad adottare sistemi di Intelligenza Artificiale perseguendo obiettivi chiari e verificabili, quali l'automazione delle attività ripetitive, il miglioramento della personalizzazione dei servizi pubblici, il rafforzamento delle capacità predittive dei processi decisionali e la promozione dell'innovazione organizzativa.

L'IA è quindi concepita come uno strumento volto a liberare il personale da compiti meramente ripetitivi, consentendo una maggiore concentrazione su attività a più alto valore aggiunto, nonché a rendere i servizi pubblici più efficaci, tempestivi e proattivi attraverso l'analisi dei dati e l'utilizzo di modelli predittivi.

Le Linee Guida adottano inoltre come modello di riferimento il ciclo di vita dei sistemi di Intelligenza Artificiale elaborato dall'Organisation for Economic Co-o-

peration and Development (OCSE), articolato in diverse fasi che accompagnano l'intero sviluppo e utilizzo del sistema: dalla pianificazione e progettazione iniziale, alla raccolta e preparazione dei dati, fino alla costruzione e all'addestramento dei modelli, alle attività di *testing*, validazione e messa in esercizio del sistema. A queste fasi seguono la fase di operatività e monitoraggio continuo – volta a verificare il corretto funzionamento del modello, l'eventuale insorgenza di *bias* e il raggiungimento degli obiettivi prefissati – e, infine, la fase di ritiro o disattivazione del sistema, che prevede la gestione sicura dei dati e la documentazione delle operazioni finali.

L'adozione di tale modello consente di inquadrare l'utilizzo dell'IA come un processo strutturato, nel quale le attività di controllo e valutazione devono essere integrate lungo tutto il ciclo di vita del sistema.

Il Capitolo 4 introduce, poi, un modello strutturato per l'adozione dei sistemi di Intelligenza Artificiale che si basa sul ciclo di miglioramento continuo Plan-Do-Check-Act (PDCA)⁶⁰ e sulle pratiche gestionali previste dallo standard internazionale ISO/IEC 42001:2023,⁶¹ che definisce i requisiti per i sistemi di gestione dell'IA.

L'obiettivo è fornire alle Amministrazioni un metodo organizzativo sistematico per pianificare, implementare, controllare e migliorare nel tempo l'utilizzo dell'IA. Le Linee Guida raccomandano che le PA adottino questo modello adattandolo alle proprie caratteristiche organizzative e al ruolo ricoperto nell'ecosistema dell'IA, ad esempio come fornitori del sistema o come soggetti che lo utilizzano (*deployer*). Nei casi in cui i sistemi presentino un livello di rischio limitato, minimo o nullo, le diverse fasi del processo possono essere semplificate o accorpa-

⁶⁰ Il Plan-Do-Check-Act (PDCA) è un modello di gestione e miglioramento continuo dei processi, diffuso nella gestione della qualità e nei sistemi organizzativi. Il ciclo si articola in quattro fasi: Plan, in cui si pianificano obiettivi e attività; Do, in cui le azioni pianificate vengono attuate; Check, che consiste nella verifica dei risultati ottenuti rispetto agli obiettivi; e Act, fase in cui si adottano misure correttive o di miglioramento. Il processo è ciclico, poiché le informazioni raccolte nella fase finale alimentano una nuova pianificazione, consentendo un adattamento costante delle attività e una progressiva ottimizzazione dei risultati.

⁶¹ "ISO/IEC 42001:2023 è uno standard internazionale che specifica i requisiti per stabilire, implementare, mantenere e migliorare continuamente un sistema di gestione dell'intelligenza artificiale (AIMS) all'interno delle organizzazioni. È progettato per le entità che forniscono o utilizzano prodotti o servizi basati sull'IA, garantendo uno sviluppo e un uso responsabili dei sistemi di intelligenza artificiale. È destinato a tutte le organizzazioni di qualsiasi dimensione coinvolte nello sviluppo, nella fornitura o nell'utilizzo di prodotti o servizi basati sull'IA. È applicabile in tutti i settori e pertinente per le agenzie del settore pubblico, nonché per le aziende o senza scopo di lucro.", consultabile al sito: <https://www.iso.org/standard/42001>.

te, in modo da evitare oneri organizzativi eccessivi.

L'elemento centrale di questo modello è l'adozione di un approccio iterativo e basato sul rischio. Ciò significa che l'introduzione e l'utilizzo dei sistemi di IA non devono essere considerati come un processo lineare, concluso una volta completata la fase di implementazione, ma come un ciclo continuo di pianificazione, verifica e miglioramento.

Di conseguenza – coerentemente con la logica *risk-based* adottata dall'AI Act – anche la valutazione dei rischi e degli impatti non è concepita come un'attività da svolgere una sola volta nella fase iniziale, ma come un processo costante, che accompagna l'intero ciclo di vita del sistema e si adatta all'evoluzione tecnologica, organizzativa e normativa.

In questa prospettiva, le Linee Guida raccomandano l'adozione di strumenti di *audit* e di meccanismi di monitoraggio continuo delle prestazioni dei modelli, finalizzati a individuare eventuali errori, distorsioni o effetti discriminatori derivanti dall'uso degli algoritmi.

Per ciò che riguarda la valutazione d'impatto dei sistemi, in particolare quelli qualificabili come ad alto rischio andrebbero sottoposti a specifiche pro-

cedure di analisi preventiva. Tali valutazioni comprenderebbero, ad esempio, la valutazione d'impatto sui diritti fondamentali (FRIA) e la valutazione d'impatto sulla protezione dei dati personali (DPIA), già previsti ai sensi del GDPR e dall'AI Act, i cui risultati andrebbero adeguatamente documentati e integrati nei processi decisionali dell'Amministrazione. In attesa dell'adozione di standard tecnici armonizzati a livello europeo, le Linee Guida suggeriscono inoltre di fare riferimento a standard internazionali in materia di gestione del rischio, quali la norma UNI ISO 31000 e la ISO/IEC 23894.

L'impostazione complessiva delle Linee Guida riflette, dunque, una logica regolatoria abbastanza dinamica e adattiva: da un lato, la previsione di una consultazione pubblica e di strumenti tecnici aggiornabili evidenzia la volontà di costruire un quadro regolatorio flessibile; dall'altro, l'attenzione posta sulla *governance*, sulla valutazione d'impatto e sulla gestione dei rischi mostra un approccio improntato nel concepire l'innovazione tecnologica come un processo che deve essere costantemente governato attraverso adeguati presidi organizzativi e procedurali.



La responsabilità della Pubblica Amministrazione nell'adozione di modelli di IA

Alla luce dei succitati principi, l'utilizzo di sistemi di Intelligenza Artificiale non può essere considerato un elemento idoneo ad escludere o attenuare la responsabilità dell'Amministrazione. Anche qualora una decisione sia supportata da un algoritmo, essa resta parte integrante dell'attività amministrativa e continua a essere imputabile alla Pubblica Amministrazione che ha scelto di adottare quello specifico strumento tecnologico.

A tal proposito, le Linee Guida invitano chiaramente a considerare l'Intelligenza Artificiale principalmente come uno strumento di supporto all'attività decisionale e non come un soggetto autonomo capace di sostituire la volontà dell'Am-

ministrazione. Tale impostazione è coerente sia con il principio di supervisione umana previsto dal diritto europeo sia con le garanzie riconosciute dall'art. 22 del GDPR, che tutela gli individui rispetto alle decisioni basate unicamente su trattamenti automatizzati.

Le Linee guida attribuiscono un ruolo centrale alla *governance* interna dell'ente. In particolare, la sezione dedicata alla *governance* individua negli organi direttivi della Pubblica Amministrazione il livello decisionale responsabile dell'approvazione della strategia di adozione dell'IA, dell'assegnazione delle responsabilità organizzative e dell'allocazione delle risorse necessarie per la sua implementazione.

Secondo le raccomandazioni dell'AgID, gli organi direttivi sono inoltre chiamati a supervisionare l'intero processo di integrazione delle tecnologie di IA nei servizi pubblici, garantendo che tali strumenti siano utilizzati in modo conforme alla normativa vigente e ai principi di buona amministrazione.

All'interno di questo assetto organizzativo, il Responsabile per la Transizione al Digitale (RTD) è individuato dalle Linee Guida come figura di coordinamento e la responsabilità della strategia di Intelligenza Artificiale dell'ente. L'AgID suggerisce che il RTD sia il soggetto predisposto ad assicurare la conformità dei sistemi di IA alle prescrizioni normative e alle stesse Linee guida, a riferire agli organi direttivi sull'andamento delle attività e a garantire la presenza di adeguati meccanismi di supervisione umana, soprattutto nei casi di sistemi classificati come ad alto rischio. Accanto a tale figura opererebbe poi l'Ufficio per la Transizione al Digitale (UTD), che supporta il RTD nella gestione operativa delle soluzioni di IA e nello sviluppo delle competenze tecniche necessarie.

Un ulteriore soggetto coinvolto nel

processo è il Responsabile della Protezione dei Dati (RPD) che, sempre secondo le Linee Guida, sarebbe chiamato a partecipare alla definizione della strategia di utilizzo dell'IA per garantire il rispetto della normativa in materia di protezione dei dati personali. Il suo ruolo include, tra l'altro, la conduzione delle valutazioni di impatto sulla protezione dei dati (DPIA) e la verifica della conformità dei trattamenti effettuati dai sistemi di IA alla disciplina europea in materia di *privacy*.

La responsabilità dell'Amministrazione emergerebbe dunque in modo particolarmente evidente in tutte le diverse fasi del ciclo di vita dei sistemi di Intelligenza Artificiale: selezione e classificazione in base al rischio (cioè verificare che la tecnologia adottata rientri nella definizione di "sistema di IA" prevista dall'AI Act e procedere alla sua classificazione in base al livello di rischio); configurazione; addestramento con dati tracciabili; valutazione dell'impatto sui diritti; utilizzo operativo con monitoraggio continuo; supervisione umana.

In questo contesto assumono particolare rilievo i modelli di con-

trollo denominati *human-in-the-loop*, ⁶² *human-on-the-loop* e *human-in-command*, che assicurano rispettivamente la possibilità di influenzare l'output del sistema, di intervenire sui parametri che lo determinano e di determinarne l'utilizzo nei processi decisionali.

Un ulteriore, fondamentale, profilo di responsabilità riguarda il rapporto tra l'Amministrazione e i fornitori esterni di tecnologie di IA.

Anche quando il sistema è sviluppato da soggetti privati, AgID raccomanda che le Pubbliche Amministrazioni effettuino, ove possibile, una verifica preliminare della conformità dei sistemi di IA ai requisiti applicabili (ad es. AI Act, NIS2) – verifica che costituisce una *best practice* tecnico-amministrativa volta a rafforzare la *compliance* – e che richiedano ai fornitori adeguate garanzie, anche attraverso certificazioni e documentazione tecnica.

Tale ultima previsione – di dubbia praticità ed efficacia applicativa

– oltre a presupporre un grado di preparazione piuttosto elevato del personale pubblico coinvolto, non sembra ammettere, dunque, alcuna ipotesi di delega di responsabilità pubblica né limitazione di responsabilità nei confronti dei cittadini, poiché l'Amministrazione resterebbe titolare dei dati trattati e assicurerebbe a questi ultimi la tutela dei loro diritti anche qualora si avvalsesse di soluzioni tecnologiche sviluppate da terzi.

In aggiunta a ciò, i principi di trasparenza e informazione richiedono che le Amministrazioni indichino in modo chiaro quali sistemi di IA vengono utilizzati, con quali finalità e con quali modalità vengono trattati i dati personali.

In particolare, si raccomanda che quando un cittadino interagisca con un sistema automatizzato, egli debba essere informato del fatto che la comunicazione avviene tramite un sistema di IA e che è comunque garantita la possibilità di

⁶² Secondo l'approccio "*human-in-the-loop*", i sistemi di IA devono essere utilizzati come strumenti di supporto all'attività amministrativa, senza sostituire il ruolo decisionale dell'essere umano. Ne deriva un modello di utilizzo dell'IA nella Pubblica Amministrazione fondato su un equilibrio tra efficienza algoritmica e tutela dei diritti fondamentali, che richiede la progettazione di sistemi trasparenti e controllabili, nonché la formazione del personale pubblico affinché possa esercitare in modo consapevole la funzione di supervisione.

richiedere l'intervento di un operatore umano.⁶³

Questi principi, già elaborati dalla giurisprudenza e dal diritto sovranazionale, trovano conferma nella L. 23 settembre 2025, n. 132, che pone al centro di ogni attività di sviluppo e utilizzo dei sistemi IA l'autodeterminazione umana.⁶⁴ Il legislatore italiano, in linea con quello europeo, adotta un approccio prudenziale basato sulla cosiddetta "riserva di umanità",⁶⁵ qualificando l'IA come strumento al servizio della Pubblica Amministrazione: utile al supporto istruttorio ma non destinato a sostituirla nel processo decisionale, che resta prerogativa dell'intervento umano.

Nel complesso, emerge come la responsabilità della Pubblica Ammi-

nistrazione non derivi dall'esistenza dell'algoritmo in quanto tale, ma dalle modalità con cui esso viene selezionato, configurato e utilizzato nel contesto dell'attività amministrativa.

3.3.1

IL QUADRO NORMATIVO ITALIANO SULL'IA NELLA PA: L'ART. 30 DEL CODICE DEI CONTRATTI PUBBLICI E LA LEGGE 23 SETTEMBRE 2025, N. 132

I principi appena richiamati hanno trovato di recente una specifica declinazione normativa nell'ordinamento italiano, attraverso due interventi che si muovono su piani distinti ma convergenti: l'art. 30 del nuovo Codice dei contratti pubblici (D.Lgs. 31 marzo

⁶³ Anche l'art. 30 del d.lgs. n. 36/2023 (Codice dei contratti pubblici) richiede la disponibilità del codice sorgente e di ogni elemento idoneo a comprendere le logiche algoritmiche, nonché il rispetto dei principi di non discriminazione, conoscibilità, comprensibilità e della non esclusività della decisione algoritmica, prevedendo comunque l'intervento umano capace di controllare, validare o disattendere l'esito automatizzato. AgID la raccomanda nelle Linee Guida come misura di trasparenza.

⁶⁴ L'art. 14 della L. n. 132 del 2025, nel disciplinare l'uso dell'IA nelle Pubbliche Amministrazioni, precisa che queste «utilizzano l'intelligenza artificiale allo scopo di incrementare l'efficienza della propria attività, di ridurre i tempi di definizione dei procedimenti e di aumentare la qualità e la quantità dei servizi erogati ai cittadini e alle imprese, assicurando agli interessati la conoscibilità del suo funzionamento e la tracciabilità del suo utilizzo». Puntualizza, inoltre, che «[l']utilizzo dell'intelligenza artificiale avviene in funzione strumentale e di supporto all'attività provvedimentale, nel rispetto dell'autonomia e del potere decisionale della persona che resta l'unica responsabile dei provvedimenti e dei procedimenti in cui sia stata utilizzata l'intelligenza artificiale»

⁶⁵ Sulla riserva di umanità si veda: Gallone G., *Riserva di umanità e funzioni amministrative. Indagine sui limiti dell'automazione decisionale tra procedimento e processo*, Padova, 2023.

2023, n. 36)⁶⁶ e la legge 23 settembre 2025, n. 132, recante *Disposizioni e deleghe al Governo in materia di intelligenza artificiale*.⁶⁷

L'art. 30 del Codice dei contratti pubblici è la prima disposizione di rango primario nell'ordinamento italiano a disciplinare in modo espresso l'utilizzo di procedure automatizzate, ivi inclusi i sistemi di Intelligenza Artificiale e le tecnologie di registri distribuiti, nel ciclo di vita dei contratti pubblici.

La norma riconosce alle stazioni appaltanti e agli enti concedenti la facoltà di automatizzare le proprie attività al fine di migliorarne l'efficienza (comma 1), ma ne subordina l'esercizio a precisi obblighi tecnici e procedurali.

In fase di acquisto o sviluppo delle soluzioni tecnologiche il comma 2 impone, da un lato, la disponibilità del codice sorgente, della relativa documentazione e di ogni elemento utile a comprenderne le logiche di funzionamento; dall'altro, l'inserimento, negli atti di indizione delle gare, di clausole volte ad assicurare le prestazioni di assistenza e manutenzione necessa-

rie alla correzione degli errori e degli effetti indesiderati derivanti dall'automazione.

Particolarmente significativo è il comma 3, che positivizza i tre principi cardine già elaborati dalla giurisprudenza amministrativa³ e ai quali devono conformarsi le decisioni assunte mediante automazione. Il principio di conoscibilità e comprensibilità riconosce a ogni operatore economico il diritto di sapere se è coinvolto in un processo decisionale automatizzato e di ricevere informazioni significative sulla logica utilizzata. Il principio di non esclusività della decisione algoritmica esige che nel processo decisionale sia sempre presente un contributo umano in grado di controllare, validare o smentire la decisione automatizzata. Il principio di non discriminazione algoritmica impone l'adozione di misure tecniche e organizzative idonee a impedire effetti discriminatori nei confronti degli operatori economici. Il comma 4 chiude il quadro prescrivendo alle amministrazioni l'obbligo di adottare ogni misura tecnica e organizzativa atta a rettificare i fattori

⁶⁶ D.Lgs. 31 marzo 2023, n. 36, Codice dei contratti pubblici, consultabile al sito: <https://www.normattiva.it/uri-res/N2Ls?urn:nir:stato:decreto.legislativo:2023;36>.

⁶⁷ Legge 23 settembre 2025, n. 132, Disposizioni e deleghe al Governo in materia di intelligenza artificiale, consultabile al sito: <https://www.normattiva.it/uri-res/N2Ls?urn:nir:stato:legge:2025-09-23;132>.

che comportano inesattezze dei dati e a minimizzare il rischio di errori, configurando un vero e proprio dovere di gestione del rischio algoritmico calibrato sulla ratio dell'AI Act.

L'art. 30 si segnala come la prima positivizzazione, nell'ordinamento italiano, della c.d. «riserva di umanità» e dei correlati principi di trasparenza, sindacabilità e non discriminazione delle decisioni automatizzate. La norma anticipa, in chiave settoriale, alcuni dei nodi affrontati dal Regolamento (UE) 2024/1689 e assume rilievo anche sul piano contrattuale: l'obbligo di disponibilità del codice sorgente e della documentazione tecnica, unitamente alle clausole di assistenza e manutenzione, fornisce un primo modello di clausole inderogabili nei rapporti tra stazione appaltante e fornitore di soluzioni di IA, suscettibile di estensione, in via interpretativa o per progressivi interventi normativi, ad altri ambiti dell'azione amministrativa.

Su un piano più generale interviene la legge 23 settembre 2025, n. 132, in vigore dal 10 ottobre 2025. Si tratta del primo quadro normativo organico italiano in materia di Intelligenza Artificiale: la legge si propone di disciplinare i settori rimessi alla competenza degli

Stati membri dal diritto dell'Unione e di dare attuazione coordinata al Regolamento (UE) 2024/1689. Articolata in sei capi, introduce principi generali in materia di ricerca, sperimentazione, sviluppo, adozione e applicazione dei sistemi di IA, in una dimensione espressamente antropocentrica e nel rispetto dei diritti fondamentali (artt. 1-6).

Di particolare rilievo, ai fini della presente trattazione, è l'art. 14, dedicato all'utilizzo dell'IA nella Pubblica Amministrazione. La disposizione finalizza l'impiego di tali sistemi all'incremento dell'efficienza dell'attività amministrativa, alla riduzione dei tempi procedurali e al miglioramento dei servizi resi a cittadini e imprese, ma precisa che esso deve avvenire «in funzione strumentale e di supporto all'attività provvedimentale, nel rispetto dell'autonomia e del potere decisionale della persona che resta l'unica responsabile dei provvedimenti e dei procedimenti in cui sia stata utilizzata l'intelligenza artificiale». La norma ribadisce inoltre il principio di conoscibilità del funzionamento dei sistemi e di tracciabilità del loro utilizzo, ponendo a carico delle amministrazioni l'adozione delle misure tecniche, organizzative e formative necessarie a un impiego responsabile.

A completamento del quadro inter-vengono altre disposizioni di sistema. L'art. 13 disciplina l'uso dell'IA nelle professioni intellettuali, qualificandola come strumento di supporto e ribadendo la prevalenza del lavoro umano e intellettuale. L'art. 20 designa l'Agenzia per l'Italia digitale (AgID) e l'Agenzia per la cybersicurezza nazionale (ACN) quali autorità nazionali competenti per l'attuazione della normativa europea e nazionale, con una distribuzione di funzioni che attribuisce ad AgID compiti di promozione e sviluppo e ad ACN compiti di vigilanza, anche ispettiva e sanzionatoria, e di sicurezza. L'art. 26, infine, introduce il nuovo art. 612-*quater* del codice penale, finalizzato a reprimere la diffusione di contenuti generati o alterati con sistemi di IA che cagionino un danno ingiusto alla persona rappresentata.

La legge n. 132/2025 contiene, inoltre, una delega al Governo (art. 24) per l'adozione, entro dodici mesi dall'entrata in vigore, di decreti legislativi destinati a introdurre, fra l'altro, una disciplina organica relativa all'uso di dati, algoritmi e metodi matematici per l'addestramento dei sistemi di IA, nuove fattispecie di reato in caso di uso illecito

dell'IA e strumenti di tutela civile per i soggetti danneggiati. Si tratta di una delega particolarmente significativa: è destinata, almeno in parte, a colmare la lacuna nazionale sulla responsabilità civile da sistemi di IA, ferma restando la cornice europea derivante dalla Direttiva (UE) 2024/2853.

Letti congiuntamente, l'art. 30 del Codice dei contratti pubblici e la legge n. 132/2025 configurano un assetto regolatorio italiano coerente con i principi europei di responsabilizzazione, trasparenza e supervisione umana.⁶⁸ Permangono, tuttavia, profili di incertezza non secondari: l'attesa dei decreti delegati di attuazione, la mancanza di un coordinamento espresso con le Linee guida AgID di cui al paragrafo precedente e la perdurante indeterminatezza, sul piano applicativo, dei criteri di ripartizione della responsabilità tra Pubblica Amministrazione e fornitore tecnologico. Sono nodi che, come si vedrà nel capitolo successivo, lo strumento contrattuale è chiamato a contribuire a sciogliere.

⁶⁸ vd. Cons. St., sez. VI, Sent. nn. 2270/2019, 8472/2019, 881/2020.



IA, sicurezza e responsabilità per incidenti e malfunzionamenti. Applicazioni pratiche

Nonostante le previsioni di carattere teorico-normativo appena enunciate, resta fondamentale considerare che, sul piano sostanziale, i sistemi di IA presentano rischi piuttosto eterogenei. Tra i principali si segnalano gli errori algoritmici, che possono derivare da *bug*, cattiva progettazione o comportamenti imprevedibili del modello; i *bias* nei dati, che rischiano di generare discriminazioni o decisioni distorte; i malfunzionamenti tecnici, inclusi errori di configurazione o di aggiornamento; e le vulnerabilità informatiche, che espongono dati e sistemi ad attacchi esterni.

La responsabilità nell'uso di sistemi algoritmici si dimostra dunque, nella pratica, complessa e multilivello. Quando un sistema di IA produce un errore, le conseguenze possono tradursi in decisioni amministrative illegittime e in danni concreti per i cittadini. Risulta, quindi, altrettanto complicato, in certi casi, individuare un unico soggetto responsabile in caso di danno.⁶⁹

Possono individuarsi, a tal proposito, tre principali aree di responsabilità:⁷⁰

La prima riguarda la scelta e la gestione dei dati immessi nell'algoritmo: la Pubblica Amministrazione,

⁶⁹ Sul punto: Ruffolo U. (a cura di), *Intelligenza artificiale e responsabilità*, Milano, 2017; Scognamiglio C., *Responsabilità civile ed intelligenza artificiale: quali soluzioni per quali problemi?*, in *Resp. civ.*, n. 4/2023, 1073 ss.

⁷⁰ Del Vecchio P., Bignoli V., *Le responsabilità amministrative da algoritmo e intelligenza artificiale. la responsabilità da provvedimento algoritmico sia ai fini del risarcimento del danno in sede civilistica che in sede contabile come responsabilità erariale*, cit., 330 e ss.

in quanto titolare del procedimento e dei dati, come abbiamo avuto modo di analizzare, è tenuta, nei casi previsti dalla normativa applicabile, a garantire la correttezza e la completezza degli *input*.

AgID e le *best practices* raccomandano che la PA adotti procedure documentate di selezione e controllo dei dati: la fase di selezione dei dati è cruciale, perché ogni errore negli input produce inevitabilmente output viziati. Si tratta di un ambito in cui la responsabilità ricadrebbe in maniera chiara sulla PA, che si fa carico di assicurare che l'algoritmo operi secondo le regole amministrative già stabilite.

La seconda area concerne il malfunzionamento del sistema stesso: questa area riguarderebbe esclusivamente i soggetti privati, quali l'ideatore del *software* o il produttore del sistema. Anche in presenza di input corretti, l'algoritmo può generare errori, ad esempio per fenomeni noti come "allucinazioni",

ossia produzione di dati non veritieri o inconsistenti. Il mancato inserimento di blocchi di sicurezza nei modelli *self-learning* costituirebbe un ulteriore esempio di possibile responsabilità del fornitore.⁷¹

La terza area riguarda, invece, l'irragionevolezza del risultato prodotto: in questo caso, il sistema funziona correttamente e i dati sono corretti, ma la soluzione proposta risulta ingiustificata o incoerente.

In tale ultimo caso risulta fondamentale garantire il diritto alla conoscibilità e comprensibilità della decisione algoritmica da parte del soggetto umano⁷² e, soprattutto, fornire una motivazione del provvedimento adeguata: la Pubblica Amministrazione manterrebbe, infatti, la possibilità di conformarsi oppure di discostarsi dal risultato prodotto dall'algoritmo; di conseguenza, la responsabilità della decisione finale rimarrebbe in capo alla stessa.⁷³

In ogni caso, sul punto, la giurisprudenza amministrativa sembra

⁷¹ Ruffolo U., *La responsabilità da artificial intelligence, algoritmo e smart product: per i fondamenti di un diritto dell'intelligenza artificiale self learning*, cit., 107.

⁷² Cons. St., Sez. VI, 4 febbraio 2020, n. 881.

⁷³ Cimini S., *La responsabilità civile e amministrativa di fronte alle sfide dell'intelligenza artificiale*, in CEDAP, 2026.

aver adottato un'impostazione di tipo antropocentrico nell'utilizzo dell'IA, ritenendo indispensabile individuare un centro di imputazione della decisione e della responsabilità capace di verificare la legittimità e la coerenza logica del risultato prodotto dall'algoritmo: la Pubblica Amministrazione che utilizza un algoritmo risponde del danno eventualmente subito dal soggetto destinatario degli effetti negativi del provvedimento algoritmico, ferma restando la possibilità di rivalersi sui singoli responsabili.⁷⁴

La responsabilità amministrativa si intreccia, poi, con gli obblighi di sicurezza digitale derivanti dalle normative esaminate: protezione dei dati e dei sistemi, misure di sorveglianza continua e tracciabilità di ogni operazione.

Nonostante però il nuovo quadro normativo in proposito, il problema della responsabilità, correlato

alla difficoltà nella gestione del rischio, sul piano pratico, non scompare. Alcuni casi recenti illustrano la complessità della questione.

In Italia, ad esempio, l'utilizzo di algoritmi nei sistemi di valutazione delle offerte negli appalti pubblici ha sollevato questioni rilevanti circa i limiti del controllo giurisdizionale sulle decisioni automatizzate, come evidenziato in alcune pronunce del TAR Lazio, nelle quali il giudice amministrativo ha dovuto confrontarsi con la difficoltà di ricostruire il funzionamento dell'algoritmo e di individuare con precisione il soggetto responsabile dell'eventuale errore.⁷⁵

Problematiche analoghe sono emerse anche in altri contesti europei.

In Francia, l'algoritmo di *risk scoring* utilizzato dalla Caisse Nationale d'Allocations Familiales (CNAF)

⁷⁴ Cons. St., Sez. VI, 13 dicembre 2019, n. 8472: "[...] anche al fine di applicare le norme generali e tradizionali in tema di imputabilità e responsabilità, occorre garantire la riferibilità della decisione finale all'autorità ed all'organo competente in base alla legge attributiva del potere".

⁷⁵ TAR Lazio-Roma (sez. II), Sent. 3 marzo 2025, n. 4546. Sul punto: Cesareo T., *Intelligenza artificiale, discrezionalità tecnica e limiti del controllo giurisdizionale negli appalti pubblici italiani*, in CERIDAP, n. 4/2025, 180 ss.: "Il rischio concreto è che la discrezionalità tecnica si trasformi in una sorta di schermo, quasi una cortina fumogena, dietro la quale l'opacità dell'intelligenza artificiale diventa sostanzialmente insindacabile. E questo [...] potrebbe costituire un vero e proprio "paradosso della deferenza": quanto più complessa e opaca è la tecnologia, tanto meno efficace diventa, di fatto, il controllo giurisdizionale".

per individuare potenziali frodi nelle prestazioni sociali ha sollevato un caso particolarmente emblematico. Il sistema, addestrato su un insieme eterogeneo di variabili individuali, determina in modo automatizzato quali beneficiari sottoporre a controllo, senza che i criteri di selezione siano resi accessibili agli interessati.

Nel 2024–2025, La Quadrature du Net e altre ventiquattro organizzazioni hanno contestato il meccanismo davanti al Conseil d'État, denunciandone i profili discriminatori e la totale opacità. Il *Défenseur des Droits* ha formalmente confermato che il sistema presenta caratteristiche strutturalmente discriminatorie, esercitando un impatto sproporzionato sulle fasce più vulnerabili della popolazione. Il contenzioso è attualmente pendente (2026).⁷⁶

La difficoltà di ricostruire il funzionamento dell'algoritmo rende in questi casi particolarmente proble-

matico dimostrare l'esistenza di un errore, individuare il nesso causale tra il sistema e il danno subito dal cittadino e, di conseguenza, accertare la responsabilità della Pubblica Amministrazione.

Tale opacità non è peraltro un fenomeno isolato: un precedente rilevante è rappresentato dal caso SyRI nei Paesi Bassi, sistema automatizzato di rilevazione delle frodi nel *welfare* dichiarato illegittimo dalla District Court dell'Aja nel 2020 per violazione dei diritti fondamentali e mancanza di trasparenza.⁷⁷

Rilevante in tal senso può considerarsi la recente nomina di un *software* di IA denominato "Diella" quale Ministra di Stato per l'intelligenza artificiale del governo Rama (Albania), con il compito di supportare l'esecutivo nella gestione dei contratti pubblici e nell'analisi dei dati amministrativi.⁷⁸

L'esempio assume rilievo anche al di là del perimetro applicativo del diritto dell'Unione (l'Albania è Sta-

⁷⁶ Sul punto: *CNAF's discriminatory scoring algorithm: 10 new organisations join the case before the Conseil d'État in France*, 20 gennaio 2026, consultabile al sito: <https://www.laquadrature.net>; *Discriminatory welfare risk-scoring algorithm*, consultabile al sito: <https://digitalfreedomfund.org>.

⁷⁷ District Court dell'Aja, 5 febbraio 2020, ECLI:NL:RBDHA:2020:1878.

⁷⁸ Atelli M., *Il ministro albanese fatto con l'AI, legalità ed estremismi*, in *IlSole24Ore*, 25 ottobre 2025, 14.

to candidato all'adesione, ma non Stato membro, sicché il Regolamento (UE) 2024/1689 non si applica direttamente): il caso illustra in modo paradigmatico la difficoltà di controllare in modo completo il funzionamento di sistemi complessi anche quando l'IA è formalmente qualificata come strumento di supporto alle decisioni, e di prevenire ogni possibile errore, con conseguenze non di poco conto sotto il profilo della responsabilità pubblica.

La responsabilità formale delle decisioni resta comunque in capo all'Amministrazione, ma risultano evidenti le difficoltà che l'impiego di sistemi di IA comporta nella gestione e nella prevenzione dei rischi, nonché nell'individuazione delle conseguenze dannose eventualmente derivanti dal loro utilizzo.



Coordinamento tra Linee Guida AgID, AI Act e NIS2: dove si arresta la norma e interviene il contratto

Alla luce della regolazione normativa appena descritta, il coordinamento tra le Linee Guida AgID, il Regolamento europeo AI Act e la Direttiva NIS2 contribuisce a delineare un sistema normativo stratificato, complesso e indubbiamente articolato.

Le Linee guida AgID svolgono in particolare una funzione di raccordo operativo tra il quadro normativo europeo e l'attività concreta delle Amministrazioni Pubbliche, traducendo i principi generali stabiliti dall'AI Act in indicazioni organizzative e procedurali relative al ciclo di vita dei sistemi di IA, alla qualità dei dati, alla tracciabilità delle operazioni e alla supervisione umana.

Parallelamente, l'AI Act introduce una disciplina armonizzata a livello europeo fondata su un approccio basato sul rischio, imponendo specifici obblighi ai soggetti che sviluppino o utilizzano sistemi di IA, mentre la Direttiva NIS2 rafforza il profilo della sicurezza informatica, imponendo alle Amministrazioni e agli operatori di servizi essenziali l'adozione di adeguate misure di gestione dei rischi e di prevenzione degli incidenti informatici.

Nonostante l'apparente completezza di questo sistema regolatorio, permangono, tuttavia, criticità significative, soprattutto con riferimento al tema della responsabilità e la gestione del rischio che deriva da tali sistemi.

In particolare, come già evidenziato, né l'AI Act né la NIS2, così come le stesse Linee Guida AgID, si occupano di disciplinare in modo diretto il regime risarcitorio applicabile nei casi in cui l'utilizzo di tali sistemi produca effetti dannosi.

La materia del risarcimento del danno resta infatti affidata ancora una volta alle discipline civilistiche nazionali, con la conseguenza che il quadro giuridico europeo sembra concentrarsi prevalentemente sull'imposizione di obblighi organizzativi e tecnici, senza incidere in modo determinante sulla ripartizione della responsabilità nei casi di danno già verificatosi e senza fornire indicazioni pragmatiche realmente utili sul piano applicativo.

In questo contesto emerge inoltre un ulteriore profilo problematico relativo alla distribuzione della responsabilità tra la Pubblica Amministrazione e il fornitore tecnologico.

Le normative esaminate tendono infatti a soffermarsi prevalentemente sulla responsabilità dell'Amministrazione nei confronti del cittadino destinatario del provvedimento amministrativo, ribadendo

l'impostazione antropocentrica secondo cui la decisione finale deve comunque essere imputabile a un soggetto umano.

Rimane, invece, meno definito il rapporto "a monte" tra Amministrazione e sviluppatore del sistema di IA, soprattutto nei casi in cui il danno derivi da comportamenti o risultati dell'algoritmo che non erano pienamente prevedibili né evitabili al momento della progettazione o dell'adozione del sistema.

In queste situazioni, nonostante l'esistenza di un quadro regolatorio complesso, spesso risulta difficile risalire con precisione all'origine del malfunzionamento, lasciando una lacuna normativa che non viene colmata dalle attuali disposizioni.

Proprio in tali situazioni emerge con particolare evidenza il limite dell'intervento normativo: la regolazione dei rapporti tra Amministrazione e fornitore tecnologico viene spesso rimessa alla disciplina contrattuale che governa l'acquisizione e la gestione delle soluzioni di Intelligenza Artificiale.

In questa prospettiva, il contrat-

to assume un ruolo centrale quale strumento di gestione del rischio tecnologico.

Attraverso le clausole negoziali le Amministrazioni possono infatti disciplinare in modo più puntuale aspetti quali la manutenzione del sistema, gli aggiornamenti *software*, le garanzie di funzionamento, gli obblighi di sicurezza e le modalità di gestione degli eventuali mal-funzionamenti.

Tuttavia, proprio perché tali profili vengono affidati alla regolazione contrattuale, soprattutto nel contesto degli appalti pubblici possono determinarsi situazioni tra loro eterogenee, dipendenti dal contenuto concreto dell'accordo negoziale e dal grado di precisione delle clausole relative alla responsabilità e alla gestione dei rischi tecnologici.

Ne deriva che, pur in presenza di un articolato quadro normativo europeo e nazionale, la concreta allocazione del rischio connesso all'utilizzo dei sistemi di IA continua a dipendere in larga misura dalla struttura e dal tipo di tali rapporti contrattuali.

Questo dato conferma come il contratto possa assumere una funzione sempre più rilevante non soltanto nella regolazione dei rapporti economici tra Amministrazione e operatori tecnologici, né esclusivamente nei rapporti tra soggetti privati, ma più in generale quale strumento giuridico essenziale attraverso cui governare l'incertezza e le criticità che derivano dalla natura complessa e solo parzialmente prevedibile dei sistemi di Intelligenza Artificiale.

CAPITOLO 4

**PROFILI EVOLUTIVI:
DAL LIMITE DELLA NORMA ALLA
CONTRATTUALIZZAZIONE COME
STRUMENTO RISOLUTIVO.**



La non prevedibilità degli *output* dell'IA come problema giuridico di partenza.

Dall'analisi sin qui svolta emerge, dunque, la rilevanza della non prevedibilità degli *output* come elemento determinante per un'analisi giuridica dell'utilizzo dei modelli di IA.

Si è già notato come tale caratteristica costituisca un tratto strutturale di svariati modelli di IA contemporanei, in particolare di quelli basati su tecniche di apprendimento automatico e, più specificamente, sui modelli di *deep learning*.

Questa dimensione probabilistica implica che, pur in presenza di input identici o molto simili, il sistema possa produrre risultati differenti o non completamente prevedibili. L'*output* non è quindi rigidamente

predeterminato dal programmatore, ma emerge dal funzionamento del modello addestrato su grandi quantità di dati.

Ne deriva una parziale perdita di controllo *ex ante* sul comportamento del sistema, che rende più complessa l'attribuzione delle responsabilità giuridiche in caso di errore, malfunzionamento o danno.

A tale problematica si aggiunge un ulteriore elemento di complessità rappresentato dalla limitata trasparenza di molti modelli di IA avanzati.

In particolare, nei sistemi basati su modelli di apprendimento profondo e su grandi modelli linguistici

(*Large Language Models*),⁷⁹ il funzionamento interno del sistema risulta spesso difficilmente comprensibile anche per gli stessi sviluppatori.

La mancanza di trasparenza costituisce una delle principali criticità da affrontare nella diffusione di tali tecnologie: da un lato rende più difficile per gli utenti comprendere i meccanismi decisionali dei sistemi di IA, alimentando talvolta diffidenza e resistenza alla loro adozione; dall'altro lato può ostacolare l'identificazione e la correzione di eventuali *bias* presenti nei modelli, proprio a causa della difficoltà di analizzare in modo diretto i processi decisionali sottostanti.⁸⁰

La trasparenza assume inoltre rilievo anche sotto il profilo dell'adeguamento normativo e della supervisione. Quando i processi decisionali dei sistemi risultano opachi, diventa più complesso verificare se essi rispettino

effettivamente gli standard previsti da leggi, regolamenti e linee guida. Ciò può rendere più difficile per autorità di controllo, organizzazioni e utilizzatori accertare la conformità dei sistemi di IA ai requisiti imposti dal diritto europeo.

In questo contesto si inserisce il noto problema della "*black box*", divenuta emblematica delle sfide poste dai sistemi basati su reti neurali profonde che producono decisioni attraverso processi computazionali la cui logica interna risulta in larga misura opaca. Tale opacità non rappresenta semplicemente un limite tecnico contingente, ma costituisce spesso una caratteristica intrinseca di determinate architetture algoritmiche. Come evidenziato nel quadro metodologico elaborato dal National Institute of Standards and Technology nel proprio AI Risk Management Framework (NIST),⁸¹ esiste infatti una relazione strutturale tra capacità predittiva dei

⁷⁹ Longo A., Masi G., *LLM, cosa sono: tutto ciò che bisogna sapere sui large language models*, in *Agenda Digitale*, 2025: "I large language models sono modelli di deep learning estremamente complessi, basati su reti neurali con miliardi di parametri, progettati per comprendere, interpretare e generare linguaggio naturale in forma scritta. Il loro funzionamento si basa sull'addestramento su vastissimi corpora di testi eterogenei – libri, articoli accademici, siti web, contenuti social, conversazioni online – che consente di cogliere e modellare con efficacia le strutture sintattiche, semantiche, lessicali e pragmatiche della lingua umana in tutte le sue sfumature", consultabile al sito: <https://www.agenda-digitale.eu>.

⁸⁰ Lusardi G., *Assicurare l'imprevedibile: le polizze per il rischio di IA*, in *Diritto al Digitale*, 20 maggio 2024, consultabile al sito: <https://dirittoaldigitale.com>.

⁸¹ <https://www.nist.gov/itl/ai-risk-management-framework>.

modelli e loro interpretabilità: sistemi caratterizzati da elevata complessità e performance tendono a risultare meno facilmente spiegabili.

Si delinea così quello che è definito un vero e proprio “paradosso della trasparenza”: i sistemi di Intelligenza Artificiale più avanzati e performanti, proprio perché fondati su architetture algoritmiche altamente complesse, risultano spesso anche i meno interpretabili sotto il profilo del loro funzionamento interno.⁸² Questa tensione tra efficacia tecnologica ed esigenza di comprensibilità rappresenta uno dei nodi centrali del dibattito giuridico e regolatorio sull’IA.

Tale lettura non è tuttavia priva di obiezioni nella letteratura tecnica più recente. Una parte autorevole della scienza dei dati ha contestato la natura ineluttabile del *trade-off* fra accuratezza e interpretabilità, sostenendo che, per i contesti decisionali ad alto impatto, sia preferibile progettare modelli intrinsecamente interpretabili piuttosto che sviluppare metodi post hoc di spie-

gazione di modelli opachi (cfr. C. Rudin, *Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead*, in *Nature Machine Intelligence*, vol. 1, 2019, 206 ss.).

La distinzione assume rilievo anche sul piano regolatorio, poiché incide direttamente sulla qualità dell’adempimento degli obblighi di trasparenza imposti dall’AI Act: una documentazione tecnica chiara e una *governance* basata su modelli interpretabili in origine offrono garanzie sostanziali più robuste rispetto a tecniche di *Explainable AI* applicate a sistemi *black box* già addestrati.

Queste caratteristiche pongono un problema giuridico di fondo: il modello tradizionale di imputazione della responsabilità, costruito attorno all’idea di controllo e prevedibilità di un comportamento, pur conciliato con gli obblighi di prevenzione introdotti dalla legislazione europea e nazionale, risulta in ogni caso parzialmente inadeguato

⁸² Responsabilità dei sistemi AI e decisioni automatizzate: il nuovo paradigma giuridico dell’era algoritmica, in *ICT Security Magazine*, 27 gennaio 2026, consultabile al sito: <https://www.ictsecuritymagazine.com>.

e insufficiente quando applicato ai sistemi di IA.

Se il comportamento del sistema non è completamente governabile e prevedibile *ex ante* e se i processi decisionali risultano in parte opachi, diventa più complesso stabilire quando un determinato risultato sia imputabile a un difetto del sistema, a un errore nell'addestramento, a un uso improprio da parte dell'utente o a fattori esterni non controllabili.

In questo senso, il limite della norma non deriva soltanto da una eventuale lacuna del Legislatore, ma trova la propria ragione nella natura stessa della tecnologia regolata.

L'IA introduce infatti una dimensione di incertezza strutturale che difficilmente può essere eliminata attraverso un incremento degli obblighi normativi o mediante una regolazione più dettagliata. Anche un sistema regolatorio particolarmente articolato non sarebbe in grado di prevedere tutte le possibili configurazioni di rischio derivanti dall'interazione tra modelli di IA, utenti e contesti applicativi.

Di conseguenza, il problema giuridico non può essere affrontato esclusivamente attraverso l'imposizione di nuovi obblighi legislativi. Piuttosto, appare necessario affiancare alla regolazione pubblica strumenti giuridici più flessibili, capaci di adattarsi alle specificità dei singoli rapporti tra i soggetti coinvolti nello sviluppo, nella distribuzione e nell'utilizzo dei sistemi di Intelligenza Artificiale, alla luce delle caratteristiche proprie del singolo rapporto.

In questa prospettiva, il contratto assume un ruolo centrale, quale strumento idoneo a disciplinare in modo puntuale e preciso la ripartizione dei rischi e delle responsabilità tra le parti, in relazione al singolo caso.



La contrattualizzazione della responsabilità come risposta funzionale

Attraverso specifiche clausole contrattuali, le parti possono definire *ex ante* i limiti di utilizzo del sistema oggetto di negoziazione, le garanzie offerte dal fornitore, le responsabilità dell'utilizzatore e i meccanismi di gestione degli eventuali incidenti o malfunzionamenti.

In questo modo, il diritto non cerca tanto di eliminare l'incertezza intrinseca della tecnologia, quanto piuttosto di governarla e distribuirne i rischi in modo consapevole.

Un'applicazione di tale logica si rinviene nel segmento del *legal-tech*, ambito in cui si è progressivamente affermata una pluralità di piattafor-

me di IA dedicate al supporto della ricerca giuridica, dell'analisi documentale e della redazione di atti, fra le quali, a livello internazionale, Harvey AI, CoCounsel (Casetext, oggi Thomson Reuters) e Lexis+ AI di LexisNexis. A titolo esemplificativo si può considerare, nel contesto italiano, Lexroom AI,⁸³ piattaforma di Intelligenza Artificiale progettata per supportare avvocati e team legali nella ricerca giuridica, nell'analisi documentale e nella redazione di atti.

Secondo le informazioni pubbliche e le condizioni contrattuali della piattaforma (*Lexroom Terms and Conditions*),⁸⁴ i risultati generati dall'IA

⁸³ <https://lexroom.ai>.

⁸⁴ <https://lexroom.ai/terms-and-conditions>.

sono accompagnati da fonti normative e giurisprudenziali verificabili, consentendo agli utenti di controllare la correttezza delle informazioni prodotte. Tale approccio riduce il rischio di affidamento cieco sull'IA e assegna all'utente professionale la responsabilità finale della revisione e dell'utilizzo *dell'output*.

Inoltre, il modello contrattuale di Lexroom prevede che il servizio sia destinato esclusivamente a professionisti qualificati, come avvocati o dipartimenti legali aziendali, che dispongano delle competenze necessarie per interpretare e verificare le informazioni generate.

Gli *output* sono concepiti come strumenti di supporto o bozze preliminari, che richiedono una revisione da parte dell'utente prima dell'utilizzo. Tali accorgimenti non eliminano l'incertezza intrinseca del sistema, ma contribuiscono a renderla gestibile attraverso una combinazione di misure tecnologiche, organizzative e contrattuali.

Dal punto di vista giuridico, l'esperienza di Lexroom evidenzia come la responsabilità per l'uso dei siste-

mi di IA venga ripartita tra fornitore e utente in modo coerente con le rispettive sfere di controllo e con lo scopo di utilizzo: il fornitore si impegna a garantire il corretto funzionamento della piattaforma e la qualità delle fonti integrate nel sistema, mentre l'utente mantiene la responsabilità della verifica finale dei contenuti e della loro applicazione nel contesto professionale.

In questa prospettiva, il contratto assume una funzione di integrazione della disciplina normativa, consentendo di adattare la gestione del rischio alle specificità del singolo rapporto contrattuale.

Questa esigenza emerge con particolare evidenza anche nella gestione dei rapporti lungo l'intera *supply chain* dei sistemi di Intelligenza Artificiale.

In tale contesto, la negoziazione contrattuale assume un ruolo centrale attraverso clausole relative a dichiarazioni e garanzie, manleve, obblighi di collaborazione e assistenza, nonché meccanismi di gestione degli incidenti e di condivisione delle informazioni, nel rispetto dei limiti normativi.⁸⁵

⁸⁵ Franchi A., *Riflessioni sulla manleva*, in *Contratto e impresa*, 1, 2017, 155.

Accanto a tali profili, particolare rilievo assume anche l'individuazione del soggetto che debba assumere il ruolo di "fornitore" ai sensi dell'AI Act, con i relativi obblighi lui attribuiti.

In contesti caratterizzati da una pluralità di attori, come nel caso di sistemi sviluppati da una *software house* su incarico di un'impresa committente, la determinazione della qualifica di fornitore può richiedere una valutazione più articolata, che tenga conto delle concrete modalità di sviluppo, distribuzione e utilizzo del sistema.⁸⁶

Proprio per questo motivo, il contratto assume una funzione particolarmente rilevante nel chiarire e specificare la ripartizione delle responsabilità tra i diversi soggetti coinvolti.

Un ulteriore elemento che conferma il ruolo integrativo del contratto emerge dall'art. 25, par. 1, lett. a), dell'AI Act, secondo cui il *deployer* che apponga il proprio nome o marchio a un sistema di AI assume la qualifica di fornitore, "fatti salvi ac-

cordi contrattuali che prevedano una diversa ripartizione degli obblighi": tale previsione riconosce espressamente lo spazio della negoziazione contrattuale come strumento idoneo a modulare la distribuzione delle responsabilità tra i soggetti coinvolti, nel rispetto del quadro normativo europeo.

In questa prospettiva, la contrattualizzazione non rappresenta un elemento di tensione rispetto al quadro normativo europeo, ma piuttosto uno strumento ausiliario e complementare alla disciplina previste dall'AI Act, NIS2 e, in generale, alle politiche europee di gestione del rischio tecnologico, che consente di tradurre nella pratica operativa i principi di gestione del rischio, trasparenza e responsabilità promossi dalle normative.

La dimensione negoziale diventa così il luogo in cui le indicazioni generali della normativa vengono adattate alle specificità dei singoli rapporti economici e tecnologici, contribuendo a rendere effettiva e concretamente applicabile la governance dei sistemi di Intelligenza Artificiale.

⁸⁶ Fedi A., *Tre osservazioni sull'AI Act e il suo rapporto con il diritto dei contratti*, in *MediaLaws*, 3/2024, 284 ss.

4.2.1

CLAUSOLE CONTRATTUALI POTENZIALMENTE ORIENTATE ALLA GESTIONE DELL'IMPREVEDIBILITÀ

Dall'analisi precedente si è visto come, generalmente, nei contratti relativi a servizi basati su Intelligenza Artificiale si riscontrino disposizioni che limitano la responsabilità del fornitore in relazione a risultati inesatti o incompleti generati dal sistema, nonché clausole che escludono garanzie implicite circa l'assoluta correttezza degli *output*.

Tali pattuizioni, purché non si traducano in un grave squilibrio tra i contraenti, non risultano in contrasto con l'impianto dell'AI Act, il quale non pretende di garantire l'infallibilità dei sistemi, ma piuttosto impone obblighi di gestione del rischio, trasparenza e *accountability*.

In questo senso, il contratto deve consentire di tradurre tali obblighi in una disciplina operativa dei rapporti tra le parti, prevenendo situazioni di incertezza e potenziali contenziosi derivanti dall'utilizzo improprio o non conforme dei sistemi di IA.

Un ulteriore profilo rilevante riguarda la verificabilità delle informazioni e

delle fonti utilizzate dal sistema. Alcune piattaforme di Intelligenza Artificiale progettate per ambiti professionali specifici adottano soluzioni che consentono agli utenti di controllare direttamente le fonti su cui si basano gli *output* generati.

Su questa linea si collocano, secondo quanto dichiarato dalle stesse imprese fornitrici, anche le piattaforme già richiamate nel *legal-tech* - fra cui, in Italia, Lexroom AI - che presentano l'affidabilità e la trasparenza delle risposte prodotte dal sistema come elementi qualificanti del proprio posizionamento di mercato.

In particolare, l'*output* generato dal sistema è accompagnato da riferimenti normativi e giurisprudenziali verificabili, che l'utente può consultare per accertare la correttezza delle informazioni. Il sistema non fornisce quindi soltanto una risposta, ma rende accessibili anche le basi giuridiche su cui tale risposta è costruita.

La promessa di risultati "verificati, citabili e trasparenti", evidenziata nelle informazioni pubbliche della piattaforma, non può e non deve tuttavia essere interpretata come una garanzia assoluta di correttezza dell'*output*.

Piuttosto, essa rappresenta il risultato di una serie di strategie tecniche e organizzative finalizzate a ridurre il rischio di errore.

Tra queste rientrano l'utilizzo di *dataset* giuridici specializzati, l'integrazione con banche dati normative e giurisprudenziali e la possibilità per l'utente di verificare direttamente le fonti citate dal sistema. Tali soluzioni consentono di mitigare, senza pretendere di eliminarla completamente, l'incertezza intrinseca dei modelli di Intelligenza Artificiale generativa, prevedendo contrattualmente una verifica "umana" *dell'output* da parte dell'utilizzatore.

Ne deriva che anche nel caso di sistemi verticali e altamente specializzati, come quelli sviluppati nel settore *legal tech*, permane una dimensione di rischio legata alla natura probabilistica del funzionamento dei modelli che la regolazione normativa, da sola, difficilmente può controllare, rendendo necessario il ricorso a strumenti negoziali di gestione del rischio.

Una simile impostazione, tra l'altro, traduce sul piano contrattuale e operativo i principi di trasparenza e tracciabilità promossi dall'AI Act e contribuisce, in linea con la logica pre-

ventiva della direttiva NIS2, a rafforzare la gestione del rischio nell'impiego dei sistemi digitali.

Tale approccio, ben specificato nelle condizioni contrattuali, valorizza l'utilizzo del sistema di IA come strumento di supporto decisionale e non di sostituzione, mantenendo centrale il ruolo del professionista nella valutazione finale delle informazioni prodotte.

Di conseguenza, ciò diviene rilevante anche per la gestione dei rapporti lungo la *supply chain*. In questo contesto, il contratto può svolgere, infatti, una funzione essenziale nel disciplinare i rapporti tra i diversi attori della filiera, prevedendo, ad esempio, dichiarazioni e garanzie relative alla qualità dei dati utilizzati per l'addestramento, obblighi di collaborazione e assistenza tecnica, nonché meccanismi di manleva o di ripartizione delle responsabilità in caso di malfunzionamenti o incidenti.

Accanto a tali disposizioni, i contratti possono prevedere dichiarazioni e garanzie rese dall'utilizzatore, attraverso le quali quest'ultimo attesti di possedere le competenze tecniche e organizzative necessarie per utilizzare il sistema nel rispetto delle istruzioni fornite. Tali dichiarazioni

ni possono riguardare, ad esempio, il livello di alfabetizzazione digitale dell'utente, la disponibilità di adeguati sistemi di controllo interno o, appunto, la capacità di verificare gli *output* generati dall'Intelligenza Artificiale prima del loro utilizzo. L'obiettivo di tali clausole non è tanto quello di trasferire integralmente il rischio sull'utilizzatore, quanto piuttosto quello di garantire che il sistema venga impiegato in condizioni coerenti con le finalità e i limiti per cui è stato progettato.

Un ulteriore ambito di rilievo riguarda le clausole relative alla manutenzione, agli aggiornamenti e alla sicurezza dei sistemi. In particolare, i contratti possono prevedere obblighi specifici in capo al fornitore relativi alla manutenzione della piattaforma, alla correzione di eventuali vulnerabilità e all'aggiornamento periodico dei modelli e delle basi dati utilizzate dal sistema.

Tali disposizioni risultano coerenti non solo con la logica preventiva dell'AI Act, ma anche con le prescrizioni della Direttiva NIS2 in materia di gestione del rischio informatico e

di sicurezza delle infrastrutture digitali. In questo ambito, il contratto può disciplinare aspetti quali gli standard di sicurezza adottati (es. crittografia AES-256, certificazioni ISO 27001, ISO 22301), le procedure di *backup* e *disaster recovery*, nonché i tempi di notifica in caso di incidenti o violazioni dei dati.⁸⁷

Particolare attenzione può essere dedicata anche alla disciplina della proprietà intellettuale, dell'utilizzo dei dati e degli eventuali indennizzi derivanti da violazioni contrattuali. La definizione chiara ed esaustiva di tali profili dei diritti tutelati contribuisce indubbiamente a ridurre l'incertezza giuridica connessa all'utilizzo di sistemi di IA e a prevenire possibili controversie tra le parti, rafforzando al contempo i principi di responsabilizzazione e prevenzione che caratterizzano la regolazione europea del settore.

Accanto a questi strumenti contrattuali, un ulteriore meccanismo di gestione del rischio può essere rappresentato dall'inserimento di una polizza assicurativa accessoria al contratto, destinata a coprire i dan-

⁸⁷ Contratti SaaS: guida legale a SLA, dati e aggiornamenti (2025), op. cit.

ni eventualmente derivanti da malfunzionamenti del sistema, da errori negli *output* generati dall'IA o da violazioni involontarie di obblighi normativi.

La polizza può prevedere specifici massimali di indennizzo, eventuali franchigie o esclusioni e condizioni per l'attivazione della copertura, contribuendo a distribuire in modo più equilibrato il rischio tra i diversi soggetti coinvolti nel rapporto contrattuale.

Negli ultimi anni, numerose imprese stanno infatti valutando, insieme ai propri *broker* assicurativi, se i rischi derivanti dall'utilizzo dei sistemi di Intelligenza Artificiale possano essere ricompresi nelle coperture assicurative già esistenti – quali le polizze di responsabilità civile professionale o le assicurazioni *cyber* – oppure se sia necessario sviluppare nuovi strumenti assicurativi specificamente dedicati a tali tecnologie.

La valutazione del rischio rappresenta, del resto, un elemento centrale nel contratto di assicurazione: affinché un rischio possa essere assicurato, è necessario che esso sia almeno

in parte prevedibile e valutabile in termini di frequenza e gravità. Nel caso dell'Intelligenza Artificiale, tuttavia, la natura evolutiva dei sistemi e la rapida trasformazione delle tecnologie potrebbero rendere la valutazione del rischio particolarmente complessa, imponendo un continuo adattamento delle soluzioni assicurative disponibili.⁸⁸

Le prime soluzioni attualmente presenti sul mercato tendono quindi ad adattare le coperture assicurative esistenti alle nuove sfide, ad esempio attraverso l'introduzione di specifiche esclusioni, franchigie dedicate o limiti di copertura mirati.

In prospettiva, è possibile che il progressivo sviluppo di queste tecnologie e una maggiore conoscenza dei rischi associati al loro utilizzo consentano di elaborare strumenti assicurativi sempre più adeguati alle esigenze degli operatori.

Per rendere più concreto il quadro sinora delineato, è utile riportare a titolo esemplificativo un'ipotesi di clausola contrattuale che mostra come gli obblighi di conformità e di sicurezza previsti dall'AI Act e dalla

⁸⁸ Lusardi G., *op.cit.*

direttiva NIS2 possano essere tradotti in disposizioni operative.

Il contratto potrebbe ad esempio contenere la dicitura: *“Le Parti riconoscono che il Sistema di Intelligenza Artificiale oggetto del presente contratto opera sulla base di modelli di apprendimento automatico caratterizzati da componenti probabilistiche e, pertanto, può generare output non integralmente prevedibili né riproducibili.*

Tale caratteristica non costituisce, di per sé, vizio o difetto del servizio, purché il Fornitore mantenga un sistema di controllo, aggiornamento e logging conforme agli standard tecnici applicabili, al Regolamento (UE) 2024/1689 (AI Act) e, in particolare, agli articoli 9, 17 e 19 dello stesso.

L'Utente si impegna a utilizzare gli output generati esclusivamente come supporto decisionale, garantendo che ogni decisione finale sia oggetto di validazione da parte di un soggetto umano dotato delle competenze necessarie per interpretare e verificare i risultati prodotti.

Il Fornitore, da parte sua, si impegna a rendere disponibili le informazioni tecniche essenziali sul funzionamen-

to del sistema e sui rischi d'impiego, in modo da consentire tale supervisione.

Il Fornitore si impegna altresì a rispettare gli obblighi di sicurezza della supply chain previsti dalla Direttiva (UE) 2022/2555 (NIS2) ed eventuali normative di ricevimento, assicurando che i propri subfornitori adottino misure di cybersicurezza equivalenti e siano soggetti a verifiche periodiche.

L'Utente si obbliga a utilizzare il Sistema in conformità alle istruzioni d'uso, garantendo supervisione umana qualificata e qualità dei dati di input, nonché a sospendere immediatamente l'utilizzo in caso di rischio per la salute, la sicurezza o i diritti fondamentali.

In caso di incidente di sicurezza o malfunzionamento, il Fornitore dovrà notificare tempestivamente l'Utente e le autorità competenti (CSIRT/ACN), collaborando alla gestione dell'incidente.

Le Parti concordano che:

- *i danni derivanti da difetti di progettazione, addestramento o conformità normativa del Sistema saranno imputabili al Fornitore;*

- *i danni derivanti da uso improprio, mancata supervisione o alterazioni sostanziali del Sistema saranno imputabili all'Utente, che assumerà la qualifica di Fornitore ai sensi dell'art. 25 AI Act.*

Resta inteso che eventuali violazioni degli obblighi di sicurezza della supply chain (NIS2) da parte di subfornitori saranno imputabili al Fornitore, salvo che l'Utente abbia selezionato direttamente tali soggetti.

Le Parti cooperano nella tracciabilità e nella documentazione degli eventi, ai fini di eventuali indennizzi o coperture assicurative.

Le Parti convengono che il rischio residuo legato a eventi imprevedibili e non imputabili a violazione contrattuale sia coperto da apposita polizza assicurativa, il cui massimale e condizioni sono indicati nell'Allegato tecnico al presente contratto".

Nel complesso, l'insieme delle clausole contrattuali dimostra come il contratto possa svolgere una funzione essenziale di traduzione operativa dei principi stabiliti dalla normativa europea.

4.2.2

I LIMITI DELLA CONTRATTUALIZZAZIONE: CLAUSOLE VESSATORIE, SQUILIBRIO NEGOZIALE E NECESSITÀ DI STANDARD MINIMI

L'analisi delle clausole virtuose svolta nel paragrafo precedente non può prescindere da una constatazione già emersa nel Capitolo II: la prassi contrattuale dei principali fornitori di servizi di IA si discosta sensibilmente dal modello di equilibrio negoziale che la regolazione europea presuppone. I contratti dei big tech, predisposti unilateralmente e proposti in via prevalentemente standardizzata, concentrano sull'utente finale una quota molto significativa del rischio decisionale, applicativo e risarcitorio.

Vi concorre una combinazione ricorrente di esclusioni di garanzia, limitazioni quantitative della responsabilità, manleve a senso unico, clausole di modifica unilaterale e facoltà di sospensione del servizio in capo al fornitore.

La «contrattualizzazione» rischia, in tale contesto, di tradursi non in una distribuzione condivisa della responsabilità, ma in una traslazione integrale verso il contraente debole.

Il quadro così delineato solleva interrogativi rilevanti sotto il profilo della disciplina delle clausole vessatorie. Nei rapporti *business-to-consumer* si applica la Direttiva 93/13/CEE,⁸⁹ recepita in Italia agli artt. 33 ss. del Codice del consumo (D.Lgs. 6 settembre 2005, n. 206),⁹⁰ che presume vessatorie le clausole le quali, malgrado la buona fede, determinino un significativo squilibrio dei diritti e degli obblighi derivanti dal contratto.

Più nel dettaglio, l'art. 33, comma 2, qualifica come presuntivamente vessatorie, fra le altre, le pattuizioni che escludono o limitano la responsabilità del professionista in caso di morte o danno alla persona derivante da un suo fatto o da una sua omissione (lett. a), che limitano le azioni in caso di inadempimento totale o parziale (lett. b), che riservano al solo professionista la facoltà di recedere o di modificare unilateralmente le condizioni contrattuali (lett. e ed m) e che limitano la responsabilità per inadempimento delle obbligazioni accessorie.

Tali clausole, ai sensi dell'art. 36 Cod.

cons., sono nulle quando non abbiano formato oggetto di trattativa individuale; la nullità opera anche di ufficio nell'interesse esclusivo del consumatore.

Diverse pattuizioni rinvenibili nei Termini di OpenAI, Microsoft e Google, esaminate nel Capitolo II, presentano profili di tensione con tale disciplina. La formula «*as is and as available*», unita a tetti risarcitori molto contenuti (frequentemente parametrati al corrispettivo versato negli ultimi dodici mesi) e all'esclusione integrale dei danni indiretti, consequenziali, reputazionali e di lucro cessante, si colloca al limite estremo dello spazio negoziale consentito al professionista. Analoghe perplessità destano le clausole di modifica unilaterale dei termini, le facoltà di sospensione del servizio *ad nutum* e le manleve generali a carico dell'utente, che in concreto possono integrare ipotesi di vessatorietà presunta.

La piena valutazione della loro validità andrà condotta caso per caso, alla luce dell'effettiva trattativa individua-

⁸⁹ Direttiva 93/13/CEE del Consiglio, del 5 aprile 1993, concernente le clausole abusive nei contratti stipulati con i consumatori. Consultabile al sito: <https://eur-lex.europa.eu/legal-content/IT/ALL/?uri=celex%3A31993L0013>.

⁹⁰ Codice del consumo, D.Lgs. 6 settembre 2005, n. 206, artt. 33-37 e 128 ss.

le (di norma assente nei piani consumer) e della giurisprudenza europea di legittimità in materia di squilibrio significativo.

A rafforzare la cornice di tutela intervengono le Direttive (UE) 2019/770 e 2019/771,⁹¹ in materia rispettivamente di contratti di fornitura di contenuti e servizi digitali e di vendita di beni con elementi digitali.

Le due fonti, recepite nel Codice del consumo agli artt. 135-octies ss. e 128 ss., introducono garanzie di conformità soggettiva e oggettiva, obblighi di aggiornamento e specifici rimedi a tutela del consumatore digitale. La disciplina si applica anche ai servizi di IA generativa erogati in modalità SaaS, e con essa le clausole standard analizzate non sempre risultano pienamente compatibili.

Nei rapporti *business-to-business* l'apparato di tutela è meno strutturato ma non assente. Vengono in rilievo, in particolare, il divieto di abuso di dipendenza economica di cui all'art. 9 della legge 18 giugno 1998, n. 192, applicabile per estensione giuri-

sprudenziale ai rapporti di fornitura digitale segnati da forte asimmetria contrattuale, e il Regolamento (UE) 2022/1925 (*Digital Markets Act*),⁹² che nei confronti dei *gatekeeper* impone obblighi di equità nelle condizioni d'uso.

A livello europeo è inoltre in corso una riflessione sull'opportunità di introdurre una disciplina armonizzata delle clausole abusive nei contratti B2B nel mercato dei servizi digitali, sull'esempio di quanto già previsto dal Regolamento (UE) 2019/1150 in materia di servizi di intermediazione *online*.

In tale prospettiva, la funzione integrativa del contratto rispetto al quadro AI Act-NIS2 non può essere accolta acriticamente. Nei rapporti caratterizzati da forte squilibrio l'autonomia negoziale rischia di ridursi a mera adesione a condizioni predisposte, con effetti potenzialmente regressivi rispetto agli obiettivi di responsabilizzazione e tutela perseguiti dal Legislatore europeo.

La «contrattualizzazione virtuosa»

⁹¹ Direttiva (UE) 2019/770 del Parlamento europeo e del Consiglio, del 20 maggio 2019. Consultabile al sito: <https://eur-lex.europa.eu/legal-content/it/ALL/?uri=CELEX%3A32019L0770>.

⁹² Regolamento (UE) 2022/1925 (*Digital Markets Act*), consultabile al sito: <https://eur-lex.europa.eu/eli/reg/2022/1925/oj/eng>.

descritta nei paragrafi precedenti presuppone, infatti, una capacità negoziale effettiva tra le parti, di norma riscontrabile soltanto nei contratti *enterprise* o nei rapporti negoziati individualmente, ben difficilmente nei piani *consumer* o nelle micro e piccole imprese.

Si profila dunque, sul piano sistematico, l'esigenza di affiancare alla libera negoziazione strumenti di standardizzazione e di riequilibrio idonei a tradurre i principi di gestione del rischio in clausole minime non derogabili. In tale direzione si possono ipotizzare quattro soluzioni concorrenti.

La prima è il ricorso ai codici di condotta volontari previsti dall'art. 95 dell'AI Act, che possono includere modelli di clausole per la traslazione equilibrata del rischio.

La seconda è l'elaborazione, da parte di autorità nazionali ed europee, di clausole contrattuali tipo, sull'esempio delle *Standard Contractual Clauses* adottate dalla Commissione europea ai sensi dell'art. 46 del Regolamento (UE) 2016/679 per i trasferimenti internazionali di dati, e di quelle predisposte dall'Unione europea per gli appalti pubblici di soluzioni di

IA (*EU Model Contractual AI Clauses*, 2023).

La terza consiste nell'adozione di linee guida AgID e di modelli operativi per la Pubblica Amministrazione, idonei a fissare uno *standard* contrattuale di riferimento nei rapporti con i fornitori tecnologici. La quarta, infine, prevede un intervento legislativo settoriale, di matrice nazionale o europea, volto a tipizzare alcune clausole abusive nei contratti di fornitura di servizi di IA, in coerenza con la *ratio* di protezione del contraente debole già accolta dal Codice del consumo.

In un assetto così rinnovato il contratto manterrebbe la propria funzione di adattamento operativo ai singoli contesti, ma all'interno di un perimetro di standard minimi inderogabili. Solo a queste condizioni potrà evitarsi che, nei rapporti tra fornitori di IA e utenti, la prassi negoziale riproponga logiche di traslazione integrale del rischio incompatibili con il quadro europeo di responsabilizzazione multi-livello.



Prospettive evolutive e considerazioni conclusive

L'analisi svolta nei paragrafi precedenti evidenzia come la disciplina dei sistemi di Intelligenza Artificiale si collochi all'interno di un contesto normativo in rapida evoluzione, nel quale il Legislatore europeo ha progressivamente cercato di sviluppare strumenti volti a garantire un elevato livello di sicurezza, trasparenza e responsabilità nell'utilizzo delle nuove tecnologie. Come si è visto, l'AI Act rappresenta il primo tentativo organico di regolamentare l'Intelligenza Artificiale secondo un approccio basato sul rischio, mentre la direttiva NIS2 rafforza il quadro di sicurezza delle infrastrutture digitali e dei servizi essenziali.

Tuttavia, si è constatato che la complessità tecnica dei sistemi di IA e la pluralità di soggetti coinvolti nella

loro progettazione, sviluppo e utilizzo rendono difficile per la sola normativa pubblica disciplinare in modo esaustivo tutte le possibili configurazioni operative di tali tecnologie. I modelli di IA, si caratterizzano per un funzionamento dinamico ed evolutivo, che può generare risultati non pienamente prevedibili e che si inserisce spesso all'interno di ecosistemi tecnologici articolati, composti da diversi attori e livelli della *supply chain*.

In questo scenario, dall'analisi svolta è emerso con chiarezza che il ruolo del diritto non può limitarsi alla definizione di obblighi generali e di principi regolatori, ma deve necessariamente confrontarsi con l'esigenza di garantire strumenti applicativi in grado di adattarsi alla varietà dei contesti ope-

rativi in cui i sistemi di IA vengono impiegati.

È in questa prospettiva che emerge la funzione integrativa del contratto, quale strumento capace di tradurre i principi della regolazione europea in soluzioni operative calibrate sulle specifiche caratteristiche dei rapporti tra gli operatori economici.

La contrattualizzazione consente di adattare la distribuzione delle responsabilità alle concrete modalità di sviluppo, distribuzione e utilizzo dei sistemi di Intelligenza Artificiale, tenendo conto delle diverse posizioni dei soggetti coinvolti nella filiera tecnologica. In questo modo, il contratto contribuisce a rendere effettiva la *governance* del rischio prevista dal Legislatore europeo, permettendo di coordinare obblighi, controlli e meccanismi di cooperazione tra i diversi attori del sistema.

Da questa prospettiva, la relazione tra normativa pubblica e autonomia negoziale non deve essere interpretata in termini di contrapposizione, ma piuttosto come un rapporto di complementarità. Mentre la regolazione europea stabilisce gli standard minimi di sicurezza, trasparenza e responsabilità cui devono conformarsi i

sistemi di IA, il contratto consente di declinare tali principi in modo flessibile e adattabile alle specificità delle diverse applicazioni tecnologiche e dei contesti organizzativi in cui esse vengono implementate.

Guardando alle possibili evoluzioni future, è verosimile che il ruolo della contrattualizzazione nella disciplina dei sistemi di Intelligenza Artificiale sia destinato a rafforzarsi ulteriormente. La crescente diffusione di modelli di IA in settori strategici dell'economia e della Pubblica Amministrazione comporterà infatti un progressivo consolidamento di prassi contrattuali specializzate, capaci di affrontare in modo sempre più sofisticato le questioni relative alla gestione del rischio tecnologico, alla sicurezza dei sistemi e alla ripartizione delle responsabilità lungo la filiera digitale.

Parallelamente, anche il quadro normativo europeo potrebbe evolversi verso forme sempre più integrate di *governance* tecnologica, nelle quali la regolazione pubblica continui a definire principi e standard di riferimento, lasciando tuttavia spazio a strumenti flessibili di attuazione, tra cui la contrattazione tra gli operatori economici e l'adozione di modelli organizzativi e

di *compliance* interni alle imprese.

In questa prospettiva, la normativa potrebbe progressivamente orientarsi non tanto verso una disciplina rigida e dettagliata delle singole clausole contrattuali, quanto piuttosto verso la definizione di principi guida e requisiti minimi relativi alla gestione del rischio, alla trasparenza e alla ripartizione delle responsabilità nei rapporti contrattuali relativi ai sistemi di IA, improntati al rispetto della disciplina consumeristica e all'equilibrio tra i contraenti.

Un simile approccio consentirebbe di valorizzare il ruolo dell'autonomia negoziale senza irrigidire eccessivamente una materia caratterizzata da una forte evoluzione tecnologica.

Il Legislatore potrebbe, ad esempio, individuare alcune aree nelle quali favorire la standardizzazione di prassi contrattuali o la predisposizione di modelli di riferimento e, parallelamente, quelle che invece necessitano di maggiore flessibilità negli accordi, lasciando alle parti un margine di adattamento alle specificità dei singoli contesti applicativi e delle diverse filiere tecnologiche. Oppure, ancora, paventare l'ipotesi di istituire una polizza assicurativa obbligatoria per

i sistemi maggiormente complessi, come misura a tutela del rischio imprevedibile.

In conclusione, l'analisi dei modelli normativi e contrattuali applicabili ai sistemi di IA evidenzia come la gestione dei rischi connessi a tali tecnologie non possa certamente essere affidata esclusivamente alla regolazione legislativa. Piuttosto, essa richiede un approccio su più piani, nel quale norme pubbliche, strumenti contrattuali e misure organizzative cooperino nel costruire un sistema di *governance* capace di coniugare innovazione tecnologica e tutela degli interessi giuridici coinvolti.



BIBLIOGRAFIA

ATELLI M., *Il ministro albanese fatto con l'AI, legalità ed estremismi*, in *IlSole24Ore*, 25 ottobre 2025, 14.

BACINI M., *Da protezione a resilienza: cosa cambia con NIS2 e AI Act in azienda*, in *agendadigitale.eu*, 2026.

Cesareo T., *Intelligenza artificiale, discrezionalità tecnica e limiti del controllo giurisdizionale negli appalti pubblici italiani*, in *CERIDAP*, n. 4/2025, 180 ss.

CIMINI S., *La responsabilità civile e amministrativa di fronte alle sfide dell'intelligenza artificiale*, in *CERIDAP*, 2026.

Codice del consumo, D.Lgs. 6 settembre 2005, n. 206, artt. 33-37 e 128 ss.

Commissione europea, *EU Model Contractual AI Clauses*, 2023.

Commissione europea, *Revised Product Liability Directive – Briefing*, EPRS, 2024.

CONDITI N., *I soggetti coinvolti dall'AI ACT: uno sguardo d'insieme*, 2024.

Cons. St., sez. VI, Sent. nn. 2270/2019, 8472/2019 e 881/2020 (sui principi

di conoscibilità, non esclusività e non discriminazione della decisione algoritmica).

D.Lgs. 31 marzo 2023, n. 36, *Codice dei contratti pubblici*, art. 30.

D.Lgs. 31 marzo 2023, n. 36, *Codice dei contratti pubblici*, in particolare art. 30.

D.Lgs. 6 settembre 2005, n. 206, *Codice del consumo*, in particolare artt. 33-37 e 128 ss.

D'ANTINO V., *L'approccio basato sul rischio nell'AI Act: un nuovo paradigma di regolazione dell'intelligenza artificiale*, in *federalismi.it*, 2025, 16 ss.

DEL VECCHIO P., BIGNOLI V., *Le responsabilità amministrative da algoritmo e intelligenza artificiale, la responsabilità da provvedimento algoritmico sia ai fini del risarcimento del danno in sede civilistica che in sede contabile come responsabilità erariale*, cit., 330 e ss.

Direttiva (UE) 2019/770 del Parlamento europeo e del Consiglio, del 20 maggio 2019.

Direttiva (UE) 2022/2555 (NIS2).

Direttiva (UE) 2024/2853 del Parla-

mento europeo e del Consiglio, del 23 ottobre 2024, sulla responsabilità per danno da prodotti difettosi e che abroga la direttiva 85/374/CEE del Consiglio, in *GU L*, 2024/2853, 18 novembre 2024.

Direttiva 93/13/CEE del Consiglio, del 5 aprile 1993.

ENISA, *Implementation guidance on NIS 2 security measures*, novembre 2024.

FEDI A., *Tre osservazioni sull'AI Act e il suo rapporto con il diritto dei contratti*, in *MediaLaws*, 3/2024, 284 ss.

FRANCHI A., *Riflessioni sulla manleva*, in *Contratto e impresa*, 1, 2017, 155.

GALLONE G., *Riserva di umanità e funzioni amministrative. Indagine sui limiti dell'automazione decisionale tra procedimento e processo*, Padova, 2023.

GOLPAYEGANI D., PANDIT H.J., LEWIS D., *AIRO: An Ontology for Representing AI Risks Based on the Proposed EU AI Act and ISO Risk Management Standards*, Dublino, 2022.

ISO/IEC 23894:2023

ISO/IEC 42001:2023

L. 23 settembre 2025, n. 132, *Disposizioni e deleghe al Governo in materia di intelligenza artificiale*, in *Gazzetta Ufficiale*, Serie Generale, n. 223, 25 settembre 2025.

LAVAGNINI S., *Contratti AI in azienda: clausole essenziali e rischi legali*, in *agendadigitale.eu*, 2025.

Legge 23 settembre 2025, n. 132, *Disposizioni e deleghe al Governo in materia di intelligenza artificiale*.

LONGO A., MASI G., *LLM, cosa sono: tutto ciò che bisogna sapere sui large language models*, in *Agenda Digitale*, 2025.

LUSARDI G., *Assicurare l'imprevedibile: le polizze per il rischio di IA*, in *Diritto al Digitale*, 20 maggio 2024.

PASCUCCI S., *AI Act: la legge europea sull'intelligenza artificiale*, in *Il diritto*, quotidiano *Dike*, 2025.

Regolamento (UE) 2022/1925 (Digital Markets Act).

Regolamento (UE) 2024/1689 (AI Act).

Regolamento di esecuzione (UE) 2024/2690 della Commissione, del

17 ottobre 2024, recante modalità di applicazione della direttiva (UE) 2022/2555 per quanto riguarda i requisiti tecnici e metodologici delle misure di gestione dei rischi di cybersicurezza, in *GU L*, 2024/2690, 18 novembre 2024.

RUDIN C., *Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead*, in *Nature Machine Intelligence*, vol. 1, 2019, 206-215.

RUFFOLO U. (a cura di), *Intelligenza artificiale e responsabilità*, Milano, 2017.

SCOGNAMIGLIO C., *Responsabilità civile ed intelligenza artificiale: quali soluzioni per quali problemi?*, in *Resp. civ.*, n. 4/2023, 1073 ss.

SERAFINI G., *NIS2 & AI Act: “Stato di attuazione in UE, sinergie e sfide”*, in *cipslegal.it*, 2024.

UNI ISO 31000:2018



SITOGRAFIA

https://ai.google.dev	https://www.nist.gov
https://business.safety.google	https://www.normattiva.it
https://cloud.google.com	https://www.studiolegalestefanelli.it
https://digitalfreedomfund.org	https://www.toplegalacademy.it
https://digital-strategy.ec.europa.eu	
https://dirittoaldigitale.com	
https://eur-lex.europa.eu	
https://ildiritto.it	
https://lexroom.ai	
https://openai.com	
https://policies.google.com	
https://workspace.google.com	
https://www.agid.gov.it	
https://www.agendadigitale.eu	
https://www.avvocatitech.com	
https://www.datacamp.com	
https://www.ictsecuritymagazine.com	
https://www.intesa.it	
https://www.iso.org	
https://www.laquadrature.net	
https://www.lexopera.it	
https://www.microsoft.com	

Forum ICT Security

24^a Edizione

Auditorium della Tecnica, Roma

Novembre

18 e 19 NOVEMBRE 2026

**08 am -
04 pm**

Iscriviti sul sito web:

ictsecuritymagazine.com